

Security @ AWS

Svyatoslav Redko,
AWS Solutions Architect
September 2024

Agenda

1. Principle of Least Privilege
2. Secure Storage and Management
3. Network Configuration
4. Organizational Account Management

aws

Principle of Least Privilege

- User Access
- Best practices for selecting credential types (IAM users, roles, etc.)
- Access control mechanisms within AWS accounts and organizations (IAM policies, roles, groups)
- How IAM policies, permission boundaries, and Organization SCPs interact to determine permissions

- Resource Access
- Overview of native credential types for AWS services (access keys, instance profiles, etc.)
- Mechanisms for controlling resource access (resource-based policies, IAM roles for services)
- Access Control Lists (ACLs): When and how to use them effectively

aws

The goal

Grant users and systems the narrowest set of privileges to complete required tasks.

Principle of least privilege

aws

Balancing the goal



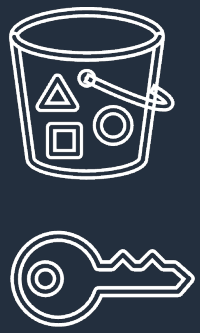
What you need to know about AWS Identity

Govern your AWS environment	with	AWS accounts and AWS Organizations
Centralize identity management	with	AWS IAM Identity Center
Rely on short-term credentials	with	federation and application roles
Organize your resources	with	tags and resource groups
Establish a data perimeter	with	policies and conditions
Journey to least privilege	with	AWS Identity and Access Management (IAM) policies and IAM Access Analyzer

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

Identity: Who can access what

Who	Can access	What
		
People and applications	Permissions	Resources

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

AWS identity management – Who

- IAM user
  - Represents a person or application
  - Not a separate account – user within your account
  - Individual passwords and access keys
- **IA**M group
  - Collection of IAM users
- IAM role
  - Not tied to one individual
  - Can be assumed by anyone who needs it

aws

AWS access management – Can access

AWS Identity and Access Management (IAM)



Identity-based policies



Resource-based policies

Two AWS policy types shown

Policies define permissions

aws

AWS resource management – What

AT CLOUD SCALE FOR . . .

Hundreds of AWS accounts

Thousands of Amazon EC2 instances

Billions of Amazon S3 objects

Trillions of Amazon DynamoDB items

And thousands of workloads

aws

Identity: user access and resource assess

User access

Resource access

Who



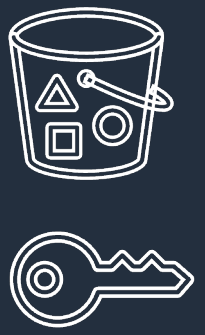
People and applications

Can access



Permissions

What



Resources

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

Tools to grant / restrict access



Grant access:

- IAM principal policies
- Access Control List (ACL)

Restrict access:

- AWS Organizations service control policies (SCPs)
- IAM permissions boundaries
- Amazon VPC endpoint policies
- Block public access

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

Specify: Tools to grant access



IAM principal policies

Attach policies to IAM identities (users, groups, or roles)

- Managed policies are standalone and attached to multiple principals
- Inline policies are attached directly to a single principal



Access Control Lists

- Grant cross-account access to a specified principal
- Cannot grant permissions to entities within the same account

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

Specify: Tools to restrict access



AWS Organizations service control policies (SCPs)

- Permissions guardrails to restrict access for principals across accounts in your organization

IAM permissions boundaries

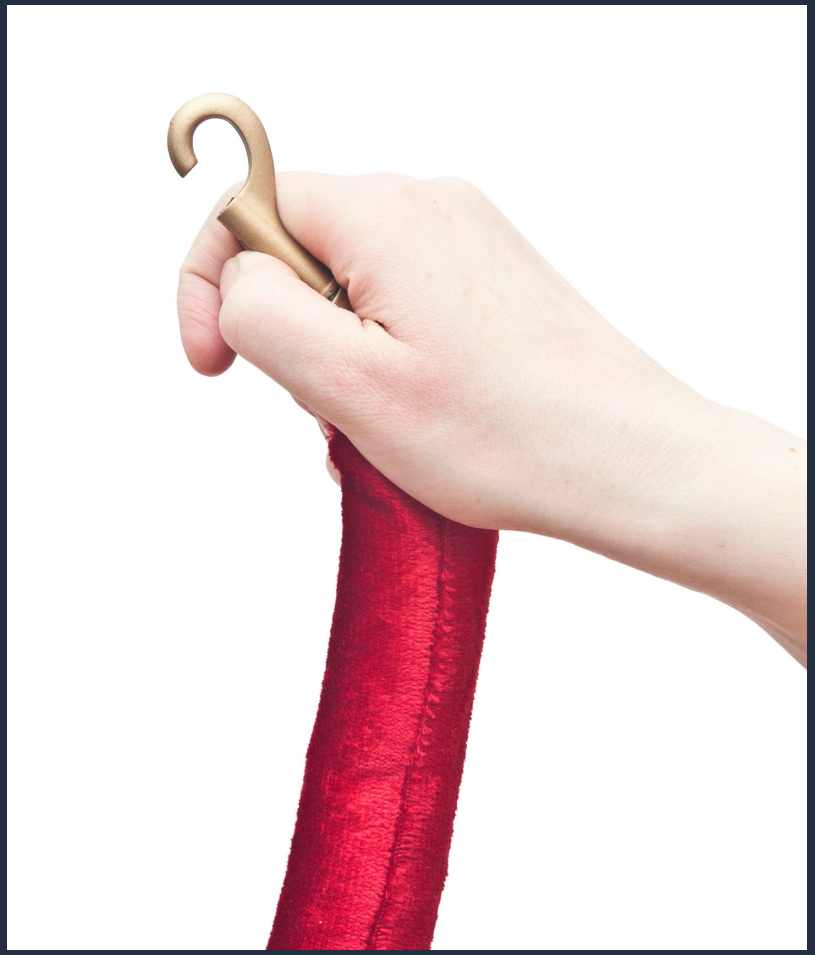
- Developers can manage permissions and control the maximum permissions they grant

Amazon VPC endpoint policies

- Require that traffic stays within your VPC

Block public access

- Block existing public access and ensure that public access is not granted to newly created items



© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

Summary



Pro tip: Use the right permissions tool





Service control policies (SCPs)



Permissions boundaries



IAM permissions policy



Scoped-down policies



Resource-based policies



Endpoint policies

Restrict powerful actions except for admins

Grant only the actions your role uses

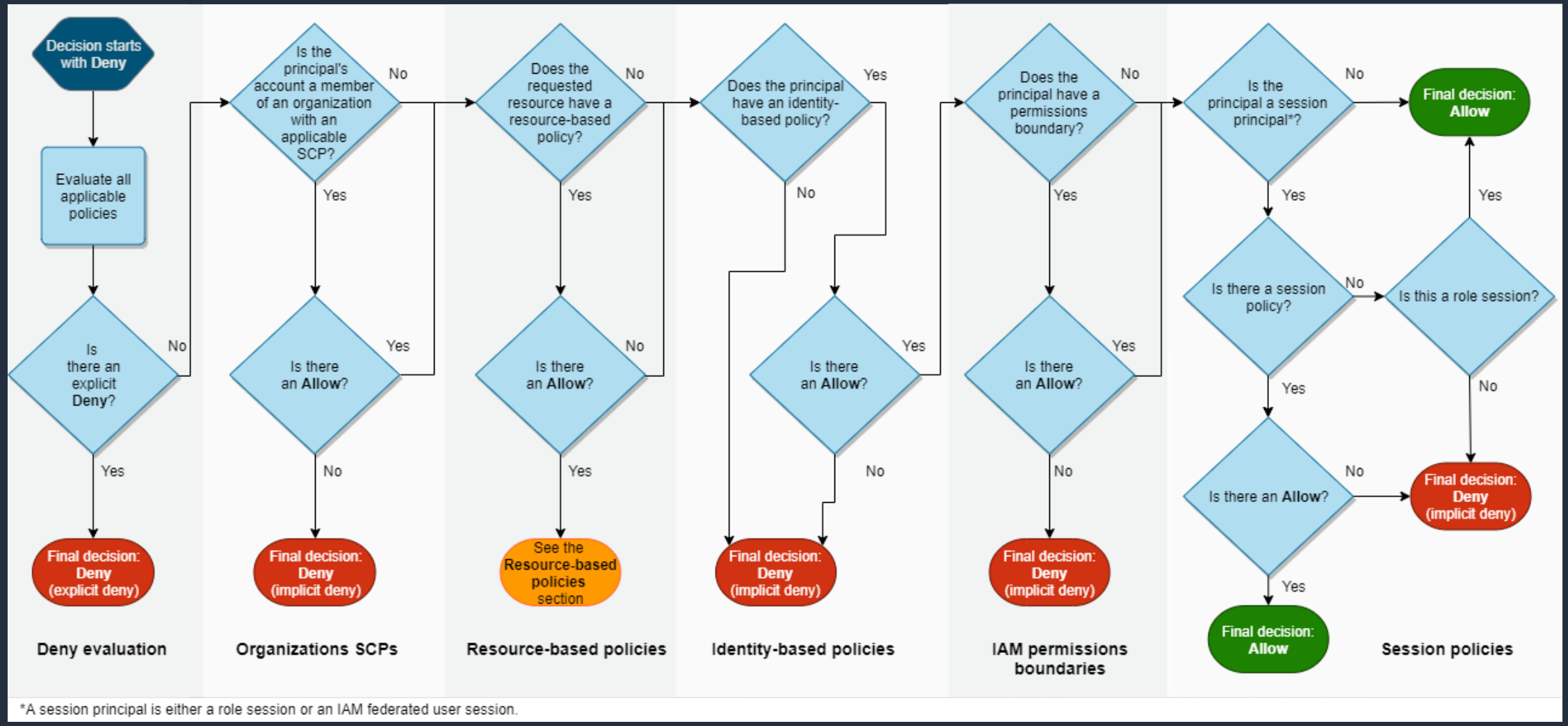
Developers can manage roles safely

Grant direct, cross-account access

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

Policy Evaluation Logic



*A session principal is either a role session or an IAM federated user session.

Enforce: How AWS evaluates policies

If using SCPs → SCP must allow

If using permissions boundaries → Permissions boundary must allow

---

If same account access → Identity **or** resource policy must allow

AWS KMS keys and IAM roles require resource policy

If direct, cross-account access → Both the identity **and** resource policy must allow

If using a session policy → Session and identity policy must allow

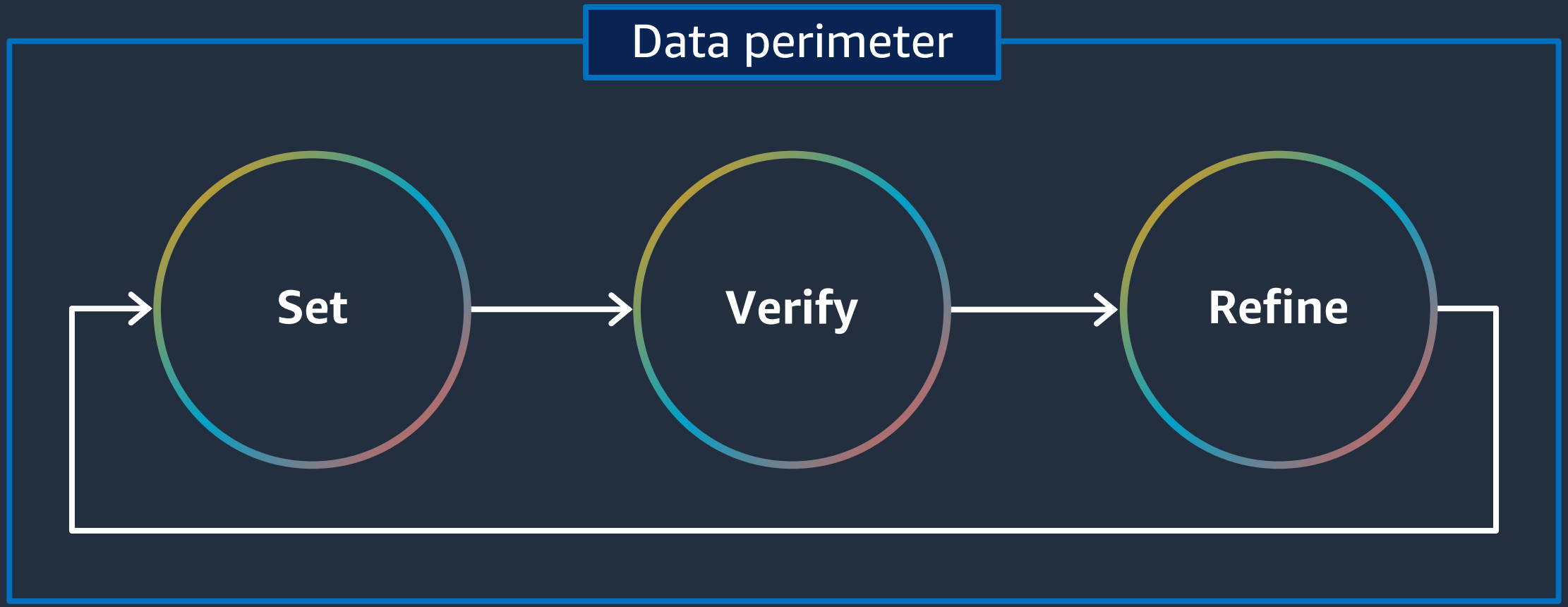
© 2022, Amazon Web Services, Inc. or its Affiliates.

aws



© 2021, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Getting to the right permissions



© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

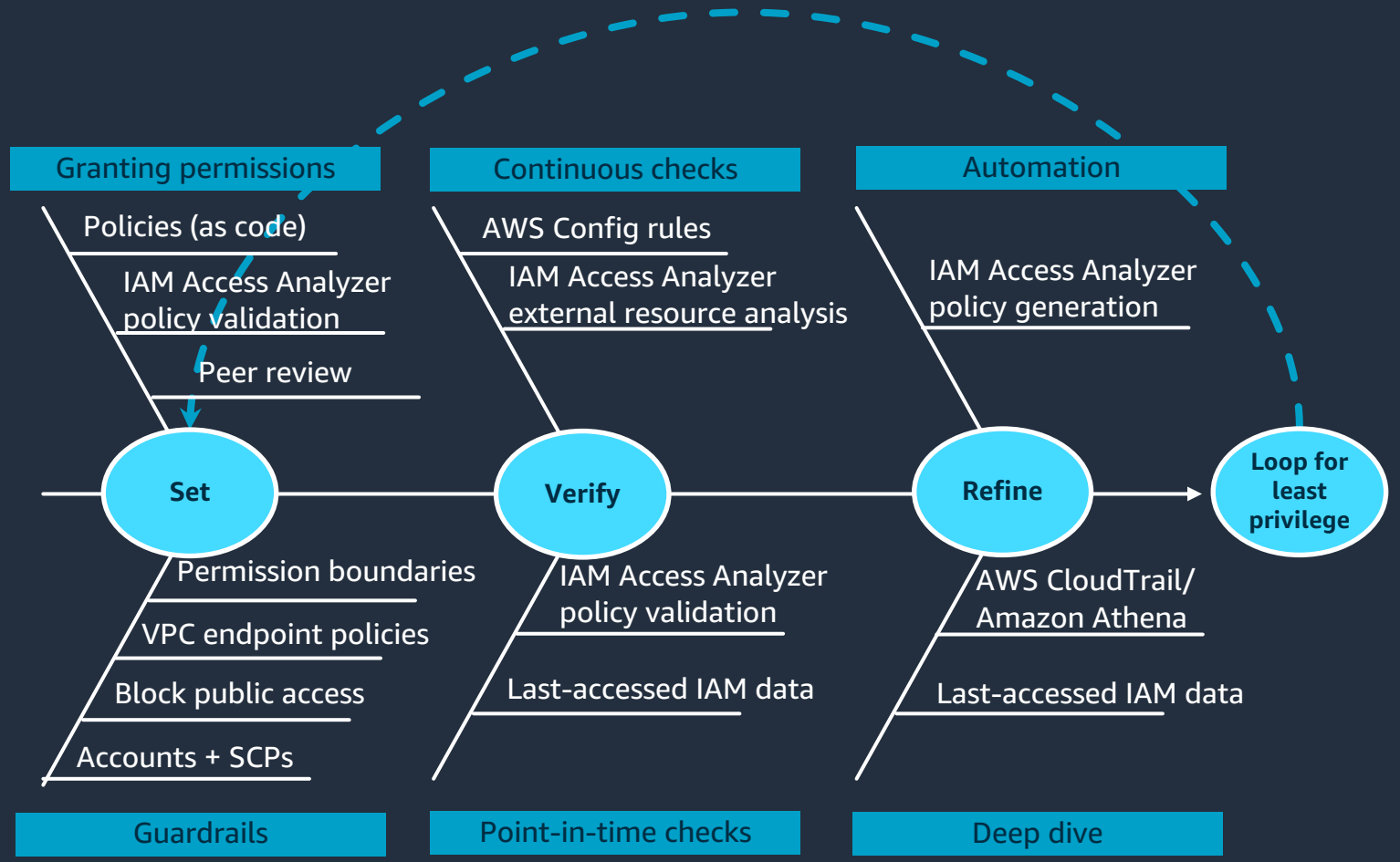
The journey to least privilege

The map is not the territory

Mental model

"A map **is not** the territory it represents, but, if correct, it has a **similar structure** to the territory, which accounts for its usefulness."

Alfred Korzybski, engineer, mathematician, and philosopher

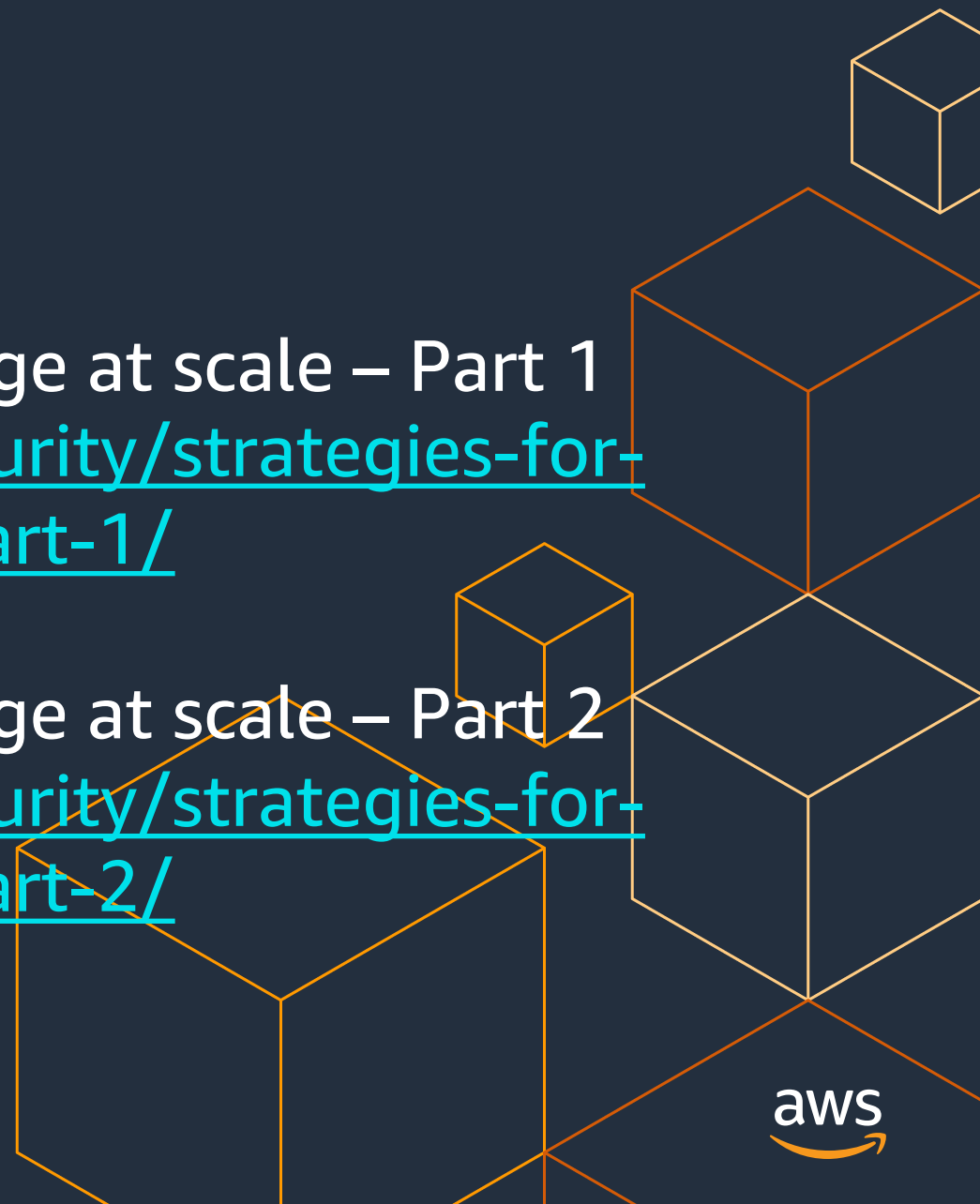


Takeaway

1. Least privilege is Architech job

2. Strategies for achieving least privilege at scale – Part 1
   https://aws.amazon.com/blogs/security/strategies-for-achieving-least-privilege-at-scale-part-1/

3. Strategies for achieving least privilege at scale – Part 2
   https://aws.amazon.com/blogs/security/strategies-for-achieving-least-privilege-at-scale-part-2/



Secure Storage and Management

- Version Control
  - Strategies for rotating secrets (AWS Secrets Manager, parameter store)
  - Parameter Store vs. Secrets Manager: Use cases, benefits, and limitations
- Encryption
  - AWS Key Management Service (KMS): Key management, encryption options
  - Service-native encryption: Encryption at rest and in transit options for various AWS services
- Review and Auditing
  - Tools and techniques for monitoring and auditing access to sensitive data
  - CloudTrail: Logging and analysis for security events

aws

1. What is AWS Secrets Manager?



AWS Secrets Manager enables customers to manage, retrieve, and rotate database credentials, API keys, and other secrets throughout their lifecycle

© 2022, Amazon Web Services, Inc. or its Affiliates.

aws

AWS Secrets Manager Use Cases

Use AWS Secrets Manager for securely storing and accessing sensitive data, such as:

- Database credentials
- Application Secrets (Lambda, EC2, ECS/EKS)
- 3rd Party API keys
- Authentication tokens
- SSH keys
- TLS keys

aws

AWS Secrets Manager strategies for rotating secrets

1. Remove plain-text secrets
2. Rotate frequently
3. Retrieve programmatically
4. Lock down permissions
5. Use unique secrets
6. Audit and monitor the use of secrets

aws

1. Remove plain-text secrets

Benefits

- Reduce risk of misuse
- Reduce “secret sprawl”
- Reduce overhead on developers

How to get started

- Pick an account strategy – manage secrets in a central account or across multiple accounts
- Find where secrets are being used
- Automate migration using AWS CloudFormation or custom tools

Pro tip:

- Operate Secrets Manager in each AWS account
- Define practices for naming, retrieving, encrypting, and rotating secrets
- Sanity check the number of secrets

aws

2. Rotate frequently

Benefits

- Improve security
- Follow best practice

How to get started

- For existing applications, first migrate the secret, then configure rotation
- For new applications, set up rotation from the start
- Create the rotation lambda function

Pro tip:

- Use the default frequency of 30 days; check your compliance and security requirements
- Pay for APIs and use of Lambda; no extra charge for rotation
- Rotation Lambda functions must be able to communicate both with the protected resource (e.g. a database) and with Secrets Manager
- Use VPC end-points
- Update the password policy according to your downstream systems
- Reuse rotation Lambda functions

aws

3. Retrieve programmatically

Benefit

- Developers don’t have to view or manage secrets

How to get started

- Create IAM roles for you applications
- Grant these IAM roles the ability to retrieve secrets
- Update code to call GetSecretValue API

Pro tip:

- Retrieve every hour
- Use client-side caching libraries, or develop your own SDK, for example similar to Spring Cloud SDK
- Place the code to retrieve outside the Lambda handler
- Schedule for deletion

aws

4. Lock down permissions

Benefits

- Support least privileges
- Less chance of human mistake

How to get started

- Identify who needs what access
- Define IAM policies
- Use resource based policies for cross-account access

Pro tip:

- Tightly control `secretsmanager:*` permissions
- Grant `ListSecrets` and `DescribeSecret` permissions
- Configuring rotation requires IAM permissions
- Separate storing, retrieving, and configuring rotation tasks
- Use tags to group secrets
- Use tag-on-create to make secrets management self-service
- Cross-account access requires CMKs

aws

5. Use unique secrets

Benefits

- Minimize blast radius
- Easily recover in restart or DR scenarios
- Minimize overhead of synchronizing secrets

How to get started

- Use CloudFormation or other tooling to provision secrets
- Require applications to retrieve secrets from the regional Secrets Manager end-point

Pro tip:

- Use unique secrets per environment, per AWS Region, per account

aws

6. Audit and monitor the use of secrets

Benefits

- Support least privileges
- Less chance of human mistake

How to get started

- Quick glance – IAM Access Advisor
- Auditable records – AWS CloudTrail Logs
- Monitor use – Amazon CloudWatch Events

Pro tip:

- Monitor attempts to retrieve secrets that are scheduled for deletion
- Monitor high value secrets
- CloudTrail records all Secrets Manager API calls; expect an increase in the size of your trails

aws

AWS Parameter Store vs AWS Secrets Manager

Feature	AWS Parameter Store	AWS Secrets Manager
Purpose	Designed for storing application configuration data, including secrets	Dedicated service for storing and managing sensitive secrets and credentials
Use Case	Suitable for non-sensitive configuration data and secrets	Suitable for sensitive secrets and credentials with advanced security requirements
Secret Rotation	No built-in rotation capabilities	Built-in rotation capabilities with integration for various AWS and third-party services
Access Control	Basic access control through IAM policies	Advanced access control policies and resource-based policies
Auditing	Limited auditing capabilities	Integrates with AWS CloudTrail for auditing and monitoring of secret access
High Availability	No built-in high availability features	Regional replication and automatic multi-Region replication for high availability
Compliance	Suitable for general compliance requirements	Designed with a strong focus on security and compliance

AWS Parameter Store is a simple and cost-effective solution for storing and managing application configuration data, including secrets, while AWS Secrets Manager is a more sophisticated and secure service specifically designed for managing sensitive secrets and credentials. The choice between the two services depends on the specific requirements of your application, such as the level of security, compliance needs, and the complexity of secret management.



2. AWS cryptography stack



Physical layer	Secure facilities and optical encryption using AES-256
Data link layer	MACsec AES-256 (IEEE 802.1AE)
Network layer	VPC Encryption | Cross-Region Peering | Amazon VPN
Transport layer	Amazon s2n | NLB-TLS | ALB | CloudFront | ACM integration
Application layer	AWS Crypto SDK | Server-side encryption with KMS integration

AWS KMS **DOES NOT** encrypt customer data

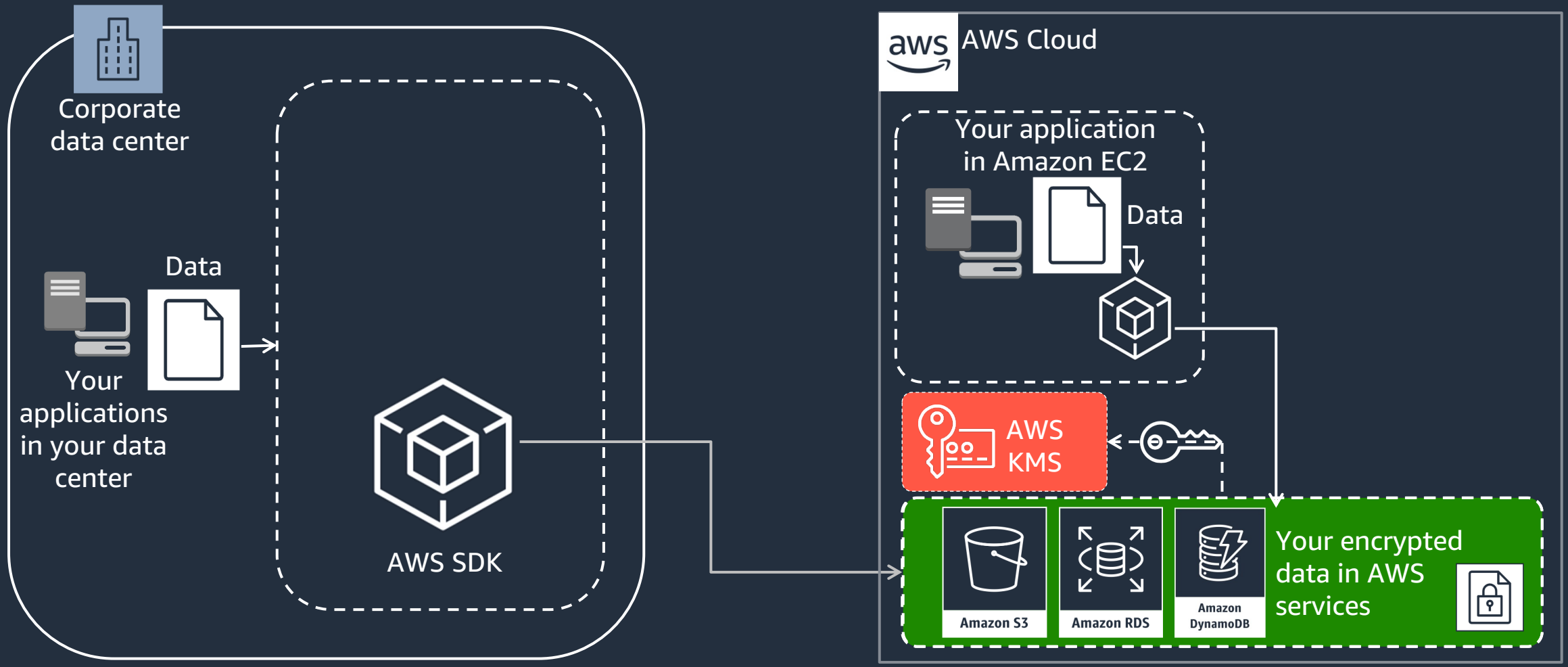
aws

AWS Key Management Service (KMS) Key Types

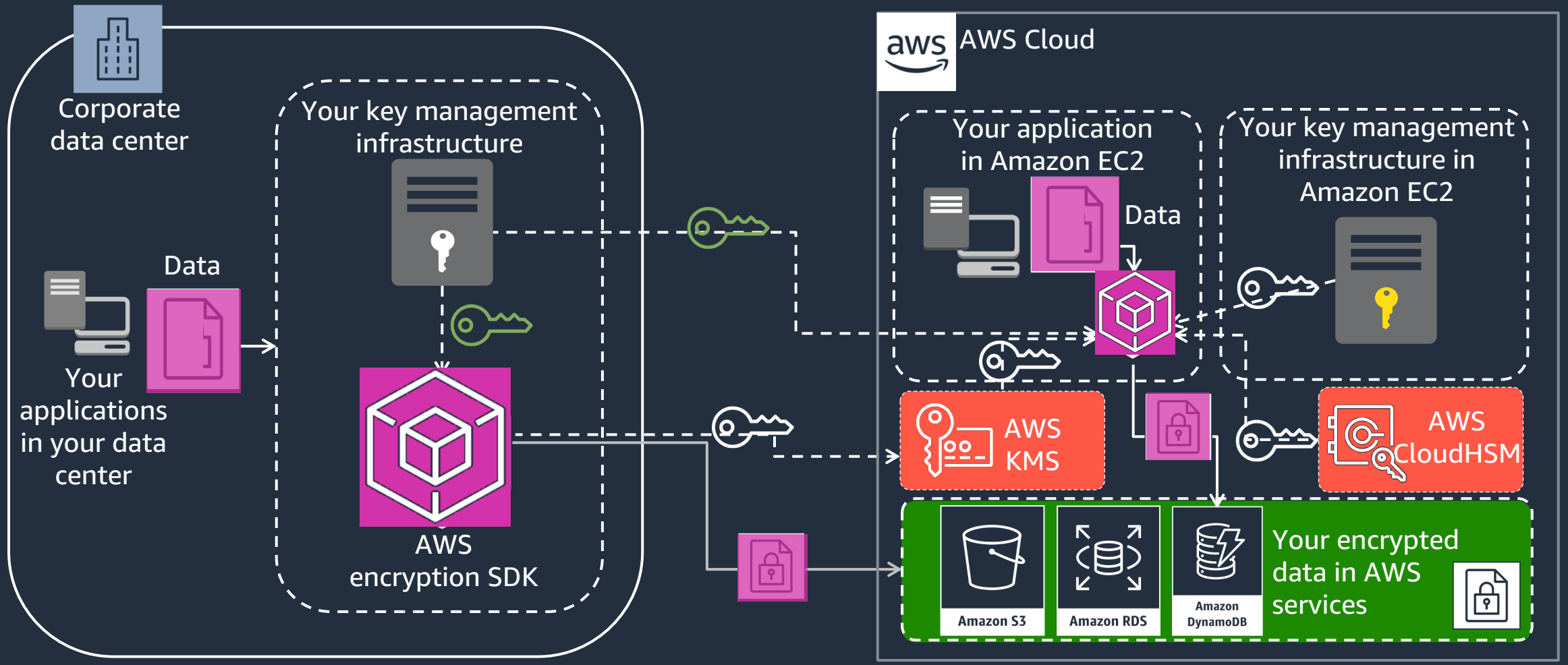
1. AWS owned keys
2. AWS managed keys
3. Customer managed keys
    - KMS stored keys
    - AWS CloudHSM stored keys
    - External (Import Key material, or BYOK) keys
    - External key store

aws

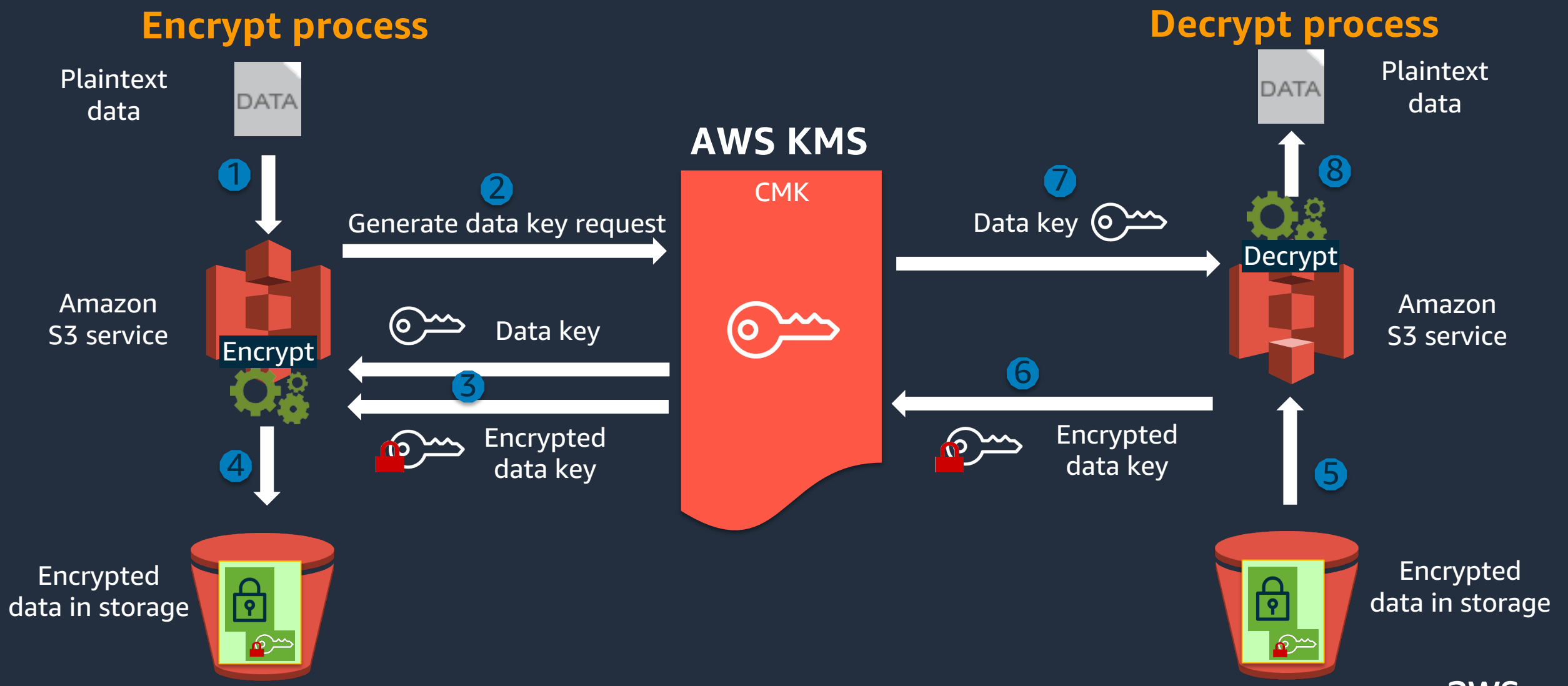
Server-side encryption: Instruct the AWS service to encrypt data after you've uploaded it



Client-side encryption: Encrypt data before you give it to an AWS service



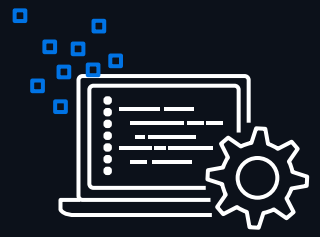
Server-side encryption in Amazon S3



3. Review and Audit: AWS CloudTrail

CloudTrail overview

- Improve governance and audits by tracking user and API activity across your infrastructure and resources
- Identify and respond to unusual activity with automated analysis



Capture
Record activity as CloudTrail events



Store
Retain event logs



Act
Trigger actions when important events are detected

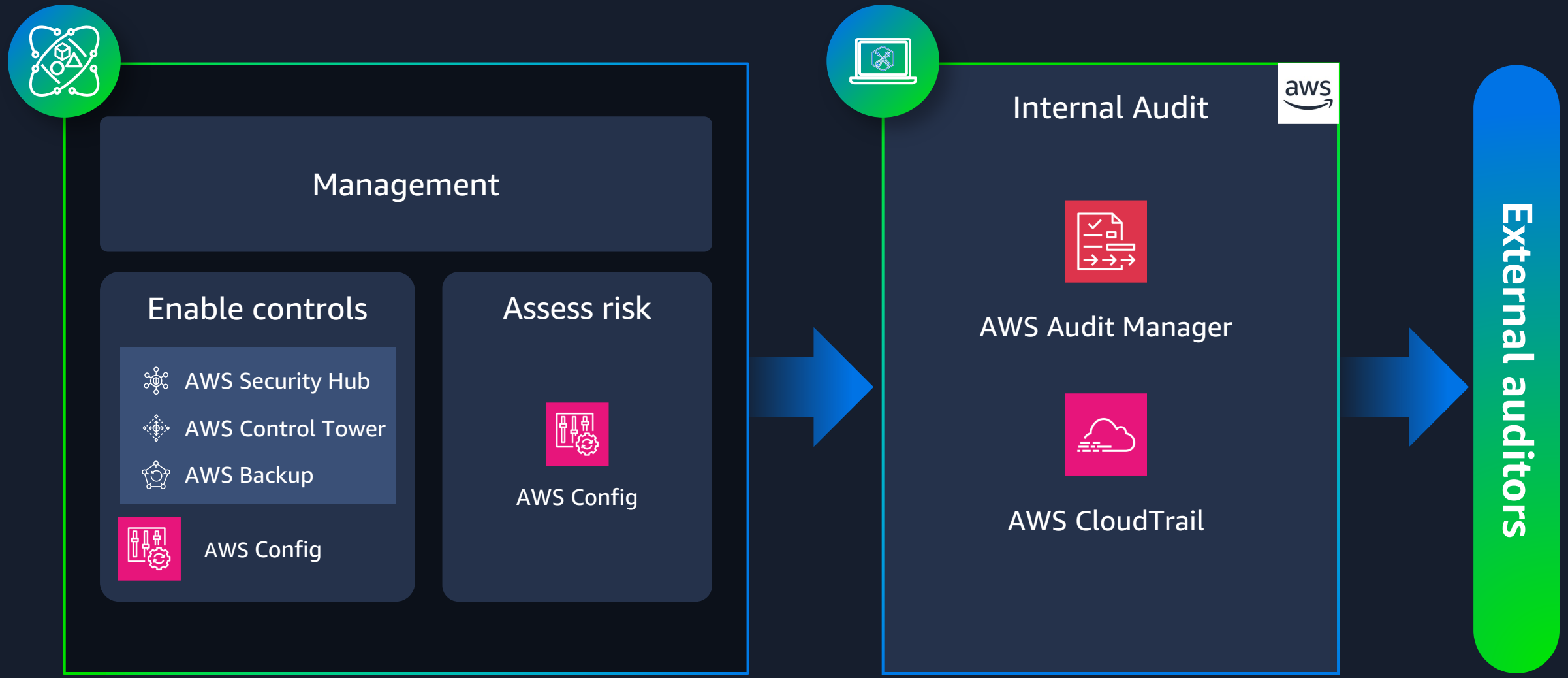


Review
Analyze findings for recent and historical activity

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

CloudTrail audit trail

Based on the Institute of Internal Auditors (IIA) Three Lines Model



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

CloudTrail

Actions taken by user, role, AWS service in AWS Management Console, AWS Command Line Interface, and AWS SDKs and APIs

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved


```
{
    "eventVersion": "1.08",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDACKCEVSQ6C2EXAMPLE",
        "arn": "arn:aws:iam::444455556666:user/Mary",
        "accountId": "444455556666",
        "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
        "userName": "Mary"
    },
    "eventTime": "2023-11-02T17:36:10Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "203.0.113.10",
    "userAgent": "Modzilla 5.0 (Macintosh; Intel Mac OS X 10_15_
    "requestParameters": {
        "userName": "Paulo"
    },
    "responseElements": {
        "user": {
            "path": "/",
            "userName": "Paulo",
            "userId": "AKIAI44QH8DHBEXAMPLE",
            "arn": "arn:aws:iam::444455556666:user/Paulo",
            "createDate": "Nov 2, 2023 5:36:10 PM"
        }
    },
    "eventCategory": "Management"
}
```

CloudTrail

Actions taken by user, role, AWS service in AWS Management Console, AWS Command Line Interface, and AWS SDKs and APIs

- Who

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved


```
{
    "eventVersion": "1.08",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDACKCEVSQ6C2EXAMPLE",
        "arn": "arn:aws:iam::444455556666:user/Mary",
        "accountId": "444455556666",
        "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
        "userName": "Mary"
    },
    "eventTime": "2023-11-02T17:36:10Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "203.0.113.10",
    "userAgent": "Modzilla 5.0 (Macintosh; Intel Mac OS X 10_15_
    "requestParameters": {
        "userName": "Paulo"
    },
    "responseElements": {
        "user": {
            "path": "/",
            "userName": "Paulo",
            "userId": "AKIAI44QH8DHBEXAMPLE",
            "arn": "arn:aws:iam::444455556666:user/Paulo",
            "createDate": "Nov 2, 2023 5:36:10 PM"
        }
    },
    "eventCategory": "Management"
}
```

CloudTrail

Actions taken by user, role, AWS service in AWS Management Console, AWS Command Line Interface, and AWS SDKs and APIs

- Who
- When

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved


```
{
    "eventVersion": "1.08",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDACKCEVSQ6C2EXAMPLE",
        "arn": "arn:aws:iam::444455556666:user/Mary",
        "accountId": "444455556666",
        "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
        "userName": "Mary"
    },
    "eventTime": "2023-11-02T17:36:10Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "203.0.113.10",
    "userAgent": "Modzilla 5.0 (Macintosh; Intel Mac OS X 10_15_
    "requestParameters": {
        "userName": "Paulo"
    },
    "responseElements": {
        "user": {
            "path": "/",
            "userName": "Paulo",
            "userId": "AKIAI44QH8DHBEXAMPLE",
            "arn": "arn:aws:iam::444455556666:user/Paulo",
            "createDate": "Nov 2, 2023 5:36:10 PM"
        }
    },
    "eventCategory": "Management"
}
```

CloudTrail

Actions taken by user, role, AWS service in AWS Management Console, AWS Command Line Interface, and AWS SDKs and APIs

- Who
- When
- What

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved


```
{
    "eventVersion": "1.08",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDACKCEVSQ6C2EXAMPLE",
        "arn": "arn:aws:iam::444455556666:user/Mary",
        "accountId": "444455556666",
        "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
        "userName": "Mary"
    },
    "eventTime": "2023-11-02T17:36:10Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "203.0.113.10",
    "userAgent": "Modzilla 5.0 (Macintosh; Intel Mac OS X 10_15_
    "requestParameters": {
        "userName": "Paulo"
    },
    "responseElements": {
        "user": {
            "path": "/",
            "userName": "Paulo",
            "userId": "AKIAI44QH8DHBEXAMPLE",
            "arn": "arn:aws:iam::444455556666:user/Paulo",
            "createDate": "Nov 2, 2023 5:36:10 PM"
        }
    },
    "eventCategory": "Management"
}
```

CloudTrail

Actions taken by user, role, AWS service in AWS Management Console, AWS Command Line Interface, and AWS SDKs and APIs

- Who
- When
- What
- How

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved


```
{
    "eventVersion": "1.08",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDACKCEVSQ6C2EXAMPLE",
        "arn": "arn:aws:iam::444455556666:user/Mary",
        "accountId": "444455556666",
        "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
        "userName": "Mary"
    },
    "eventTime": "2023-11-02T17:36:10Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "203.0.113.10",
    "userAgent": "Modzilla 5.0 (Macintosh; Intel Mac OS X 10_15_
    "requestParameters": {
        "userName": "Paulo"
    },
    "responseElements": {
        "user": {
            "path": "/",
            "userName": "Paulo",
            "userId": "AKIAI44QH8DHBEXAMPLE",
            "arn": "arn:aws:iam::444455556666:user/Paulo",
            "createDate": "Nov 2, 2023 5:36:10 PM"
        }
    },
    "eventCategory": "Management"
}
```

CloudTrail

Actions taken by user, role, AWS service in AWS Management Console, AWS Command Line Interface, and AWS SDKs and APIs

- Who
- When
- What
- How
- Results?

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved


```
{
    "eventVersion": "1.08",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDACKCEVSQ6C2EXAMPLE",
        "arn": "arn:aws:iam::444455556666:user/Mary",
        "accountId": "444455556666",
        "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
        "userName": "Mary"
    },
    "eventTime": "2023-11-02T17:36:10Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "203.0.113.10",
    "userAgent": "Modzilla 5.0 (Macintosh; Intel Mac OS X 10_15_
    "requestParameters": {
        "userName": "Paulo"
    },
    "responseElements": {
        "user": {
            "path": "/",
            "userName": "Paulo",
            "userId": "AKIAI44QH8DHBEXAMPLE",
            "arn": "arn:aws:iam::444455556666:user/Paulo",
            "createDate": "Nov 2, 2023 5:36:10 PM"
        }
    },
    "eventCategory": "Management"
}
```

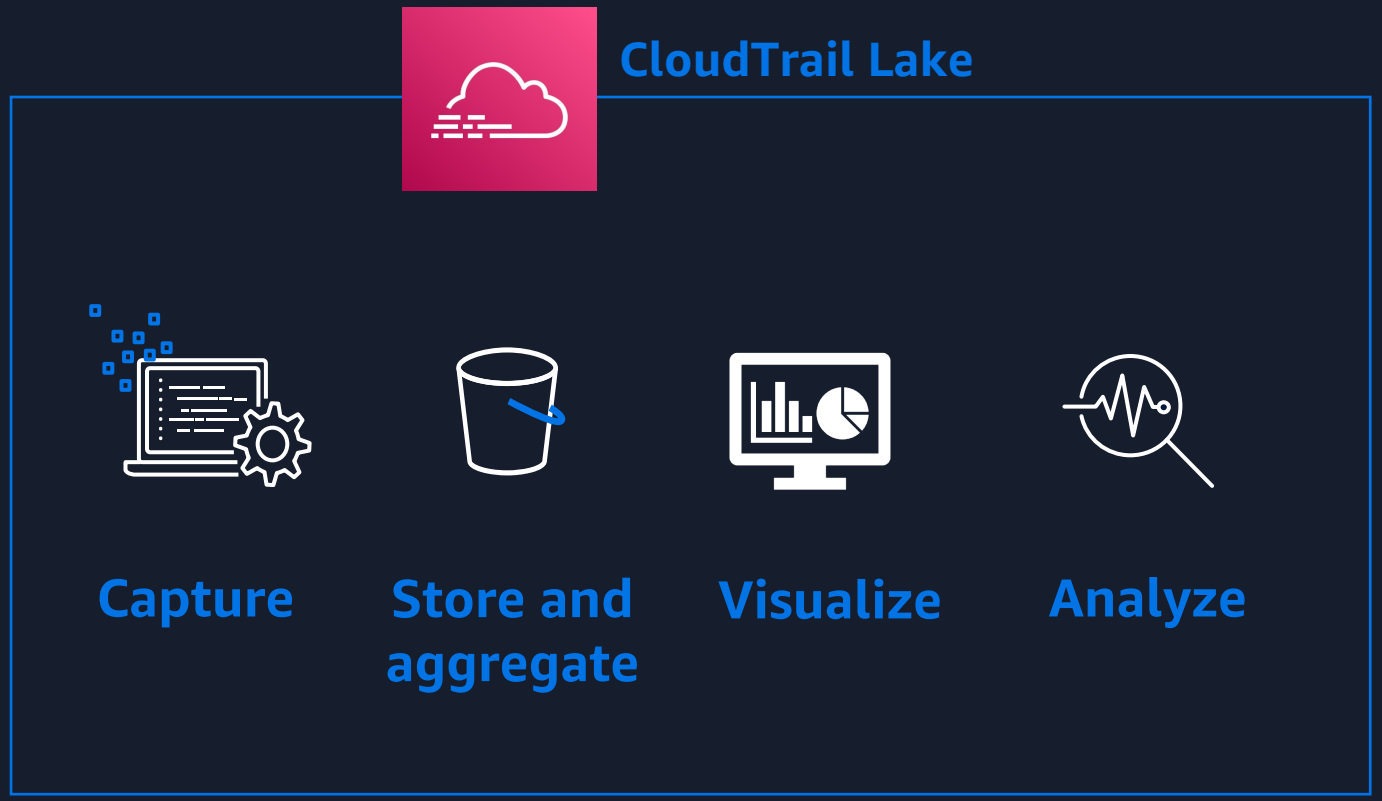
CloudTrail event types

- Management events – enabled by default
  - Records of control plane operations that are performed on or within resources
- Data events – not enabled by default
  - Records of data plane operations that are performed on or within a supported AWS resource
  - Available for Amazon S3 objects events and Lambda execution at an additional cost
- Insights events – not enabled by default
  - Records unusual call volume of write management APIs in your AWS account up to 90 days

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

CloudTrail Lake

MANAGED AUDIT DATA LAKE TO AGGREGATE, IMMUTABLY STORE, VISUALIZE, AND ANALYZE AUDIT AND SECURITY INFORMATION



Turnkey solution

Sample queries to get you started

No time spent on ETL

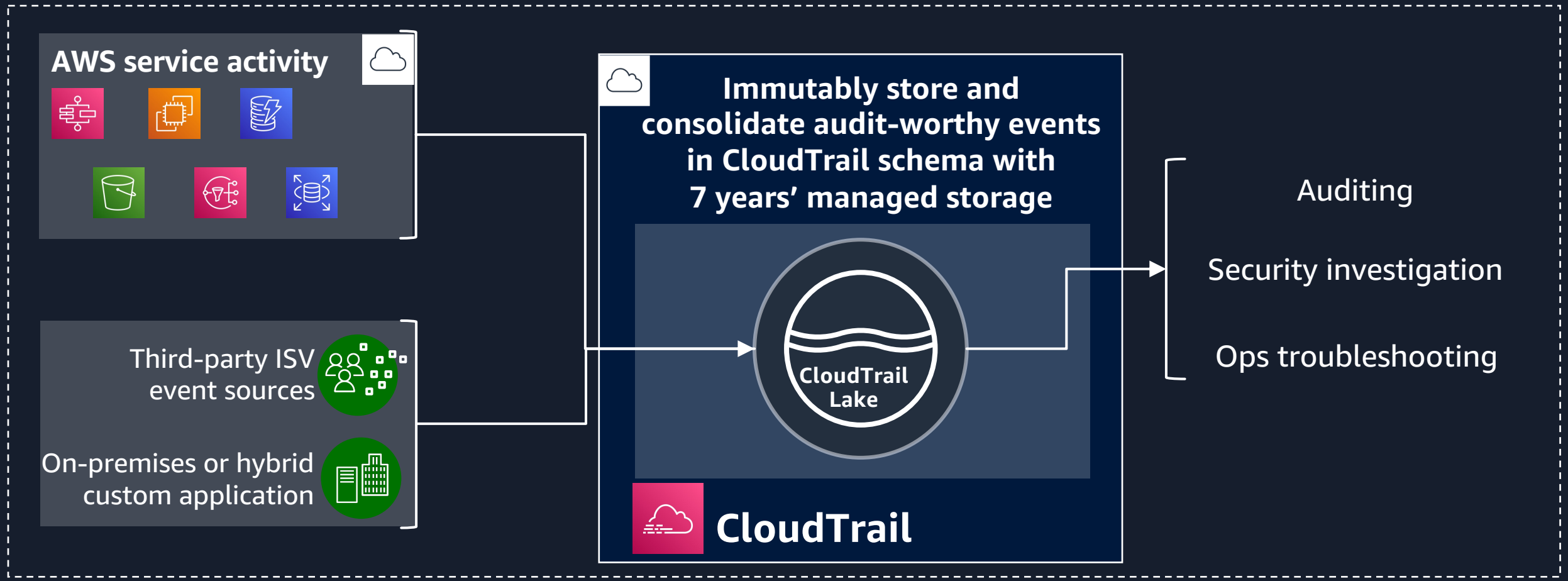
Optimized data ready for querying

Immutable storage

Read-only access

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Extending CloudTrail Lake capability to non-AWS sources



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

CloudTrail Lake non-AWS data sources

- Partner integrations (direct integration)
  - Cloud Storage Security (CSS), Clumio, CrowdStrike, CyberArk, GitHub, Nordcloud, Kong Inc., LaunchDarkly, MontyCloud, Netskope, Okta, One Identity, Shoreline, Snyk, Wiz
- Custom integrations (solution integration)
  - Application runs in your AWS account and calls the PutAuditEvents API to deliver events to your CloudTrail Lake event data store

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

AWS CloudTrail

CloudTrail Trail

(Events delivered to S3 bucket)

- Track management and data events of AWS services
- Integrates with Amazon CloudWatch, Amazon Athena, and other partner products for a DIY solution
- Customer-managed S3 bucket and policies
- CloudTrail log file validation

CloudTrail Lake

(Managed security and audit Lake)

- Track management and data events of AWS services and supported partner products (open audit events)
- Integrated SQL queries for turn-key solutions
- Managed storage with 7 years of included storage
- Immutable source of events

Free event history and lookup for 90 days of management activity

Paid insights for anomaly detection

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Takeaway

1. Use AWS Secrets Manager to store secrets, and AWS Parameter Store for non-secret params
2. Never implement enc/dec algorithms by your own
3. How Encryption Works in AWS https://www.youtube.com/watch?v=plv7PQZICCM
4. Create AWS CloudTrail Lake and collect all trails in it

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

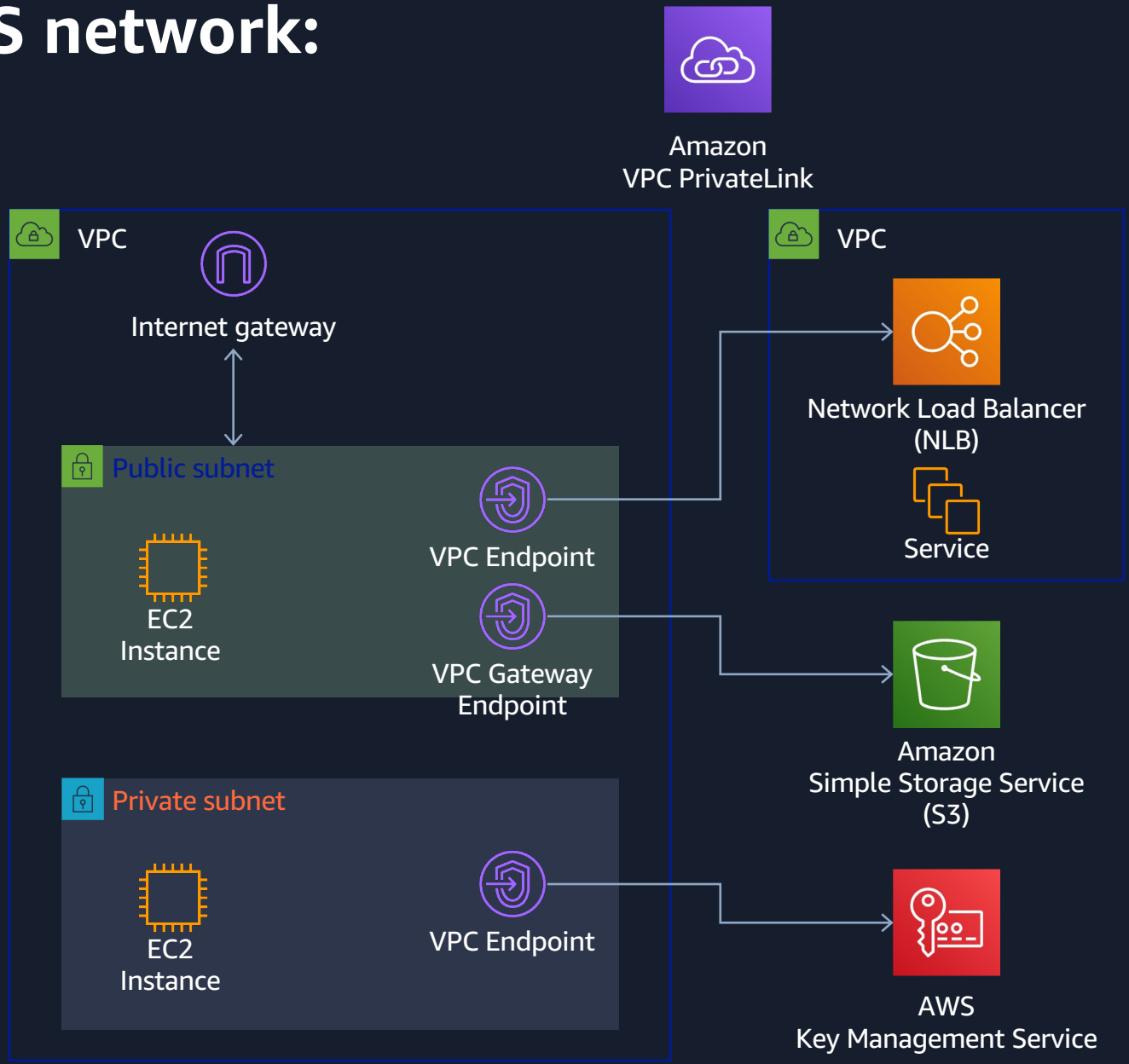
Network Configuration

- Segmentation
  - Stay on AWS network: VPC Endpoints
  - Shared VPCs: Benefits and security considerations
  - VPC Peering: Securely connecting VPCs within and across accounts
  - Transit Gateways (TGW): Simplifying network architectures and enhancing security
- Port Security
  - Security Groups: State-based firewall rules for EC2 instances
  - Network ACLs: Stateless firewall rules for subnet-level traffic control
- Additional Protection
  - Route 53 DDoS protection: Mitigating distributed denial-of-service attacks
  - Web Application Firewall (WAF): Protecting web applications from common vulnerabilities

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

1. Segmentation. Stay on AWS network: VPC Endpoints

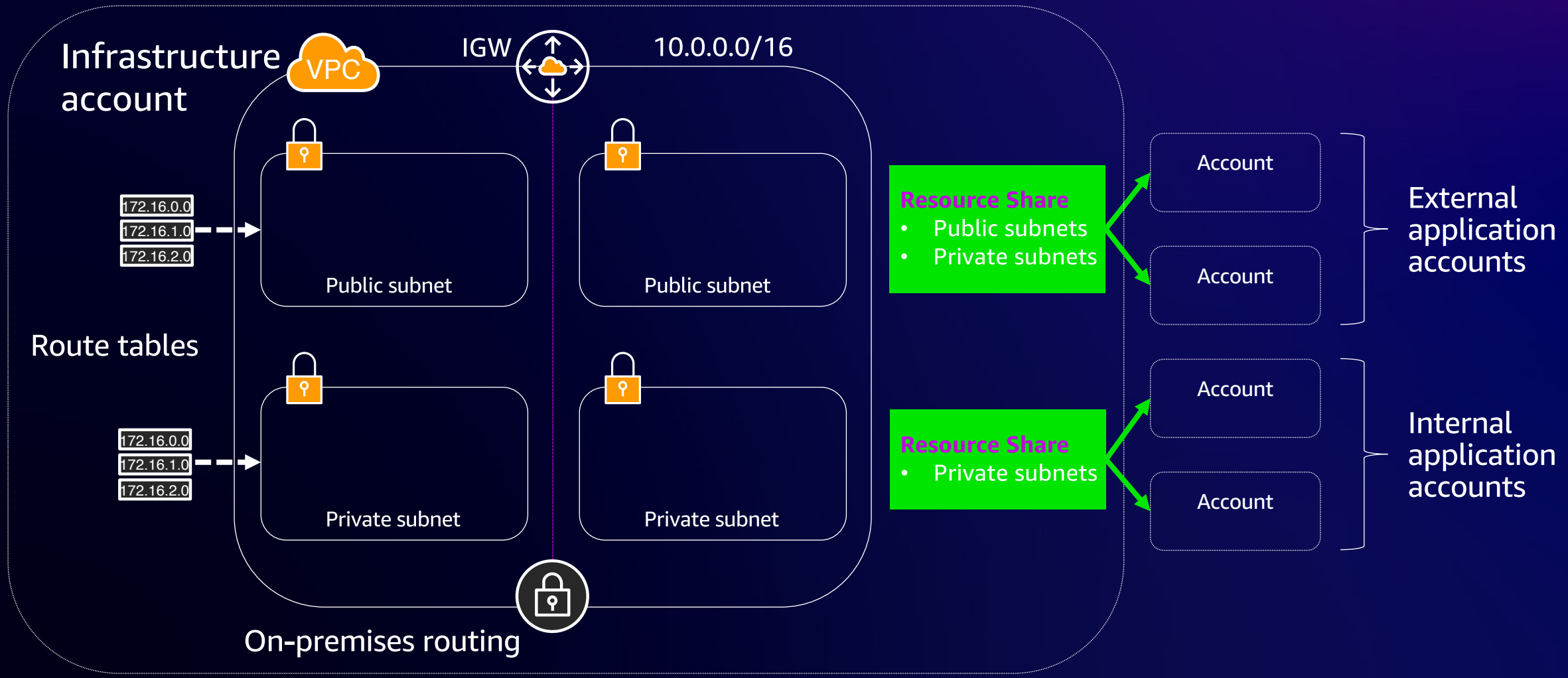
- Connect your VPC to:
  - Supported AWS services
  - VPC endpoint services powered by PrivateLink
- Doesn't require public IPs or Internet connectivity
- Horizontally scaled, redundant, and highly available
- Robust access control
- Metrics for traffic visibility



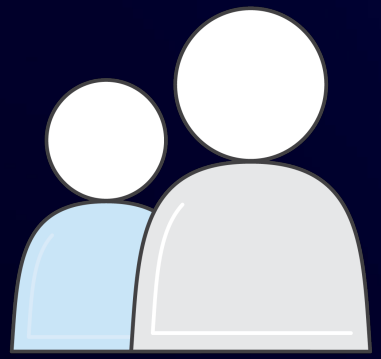
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

VPC Sharing and Resource Access Manager

- Share subnets between accounts in an AWS Organization

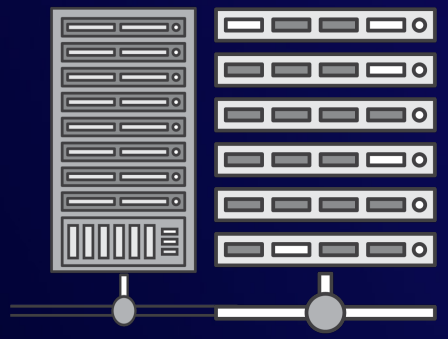


VPC Sharing benefits



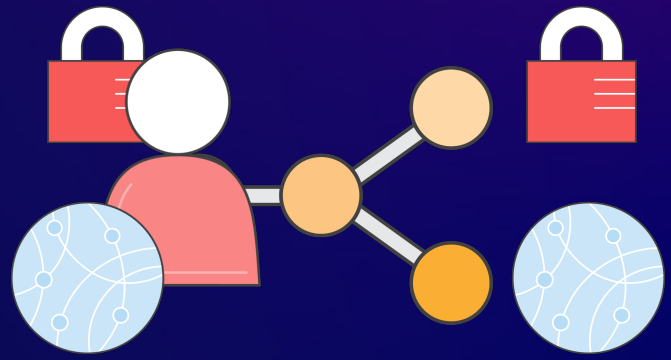
Separation of duties

- Infrastructure strictly controls routing, IP addresses, and VPC structure
- Developers own their resources, accounts, and security groups



Less unused resources

- Higher density subnets, add up to 5 additional CIDRs
- More efficient use of VPN and AWS Direct Connect



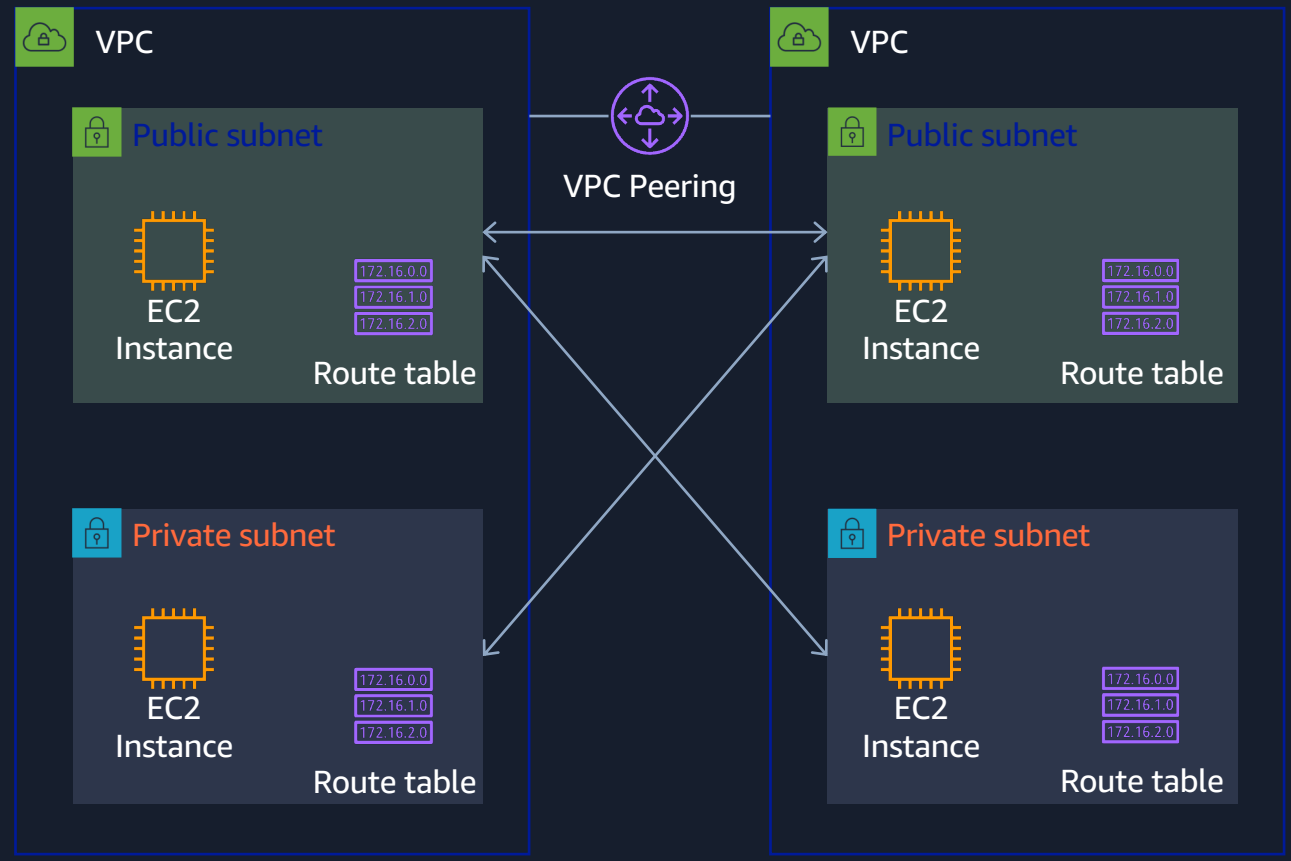
Decouple accounts and networks

- Account protection and billing without additional infrastructure
- Many accounts with fewer networks
- Avoid VPC peering charges

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

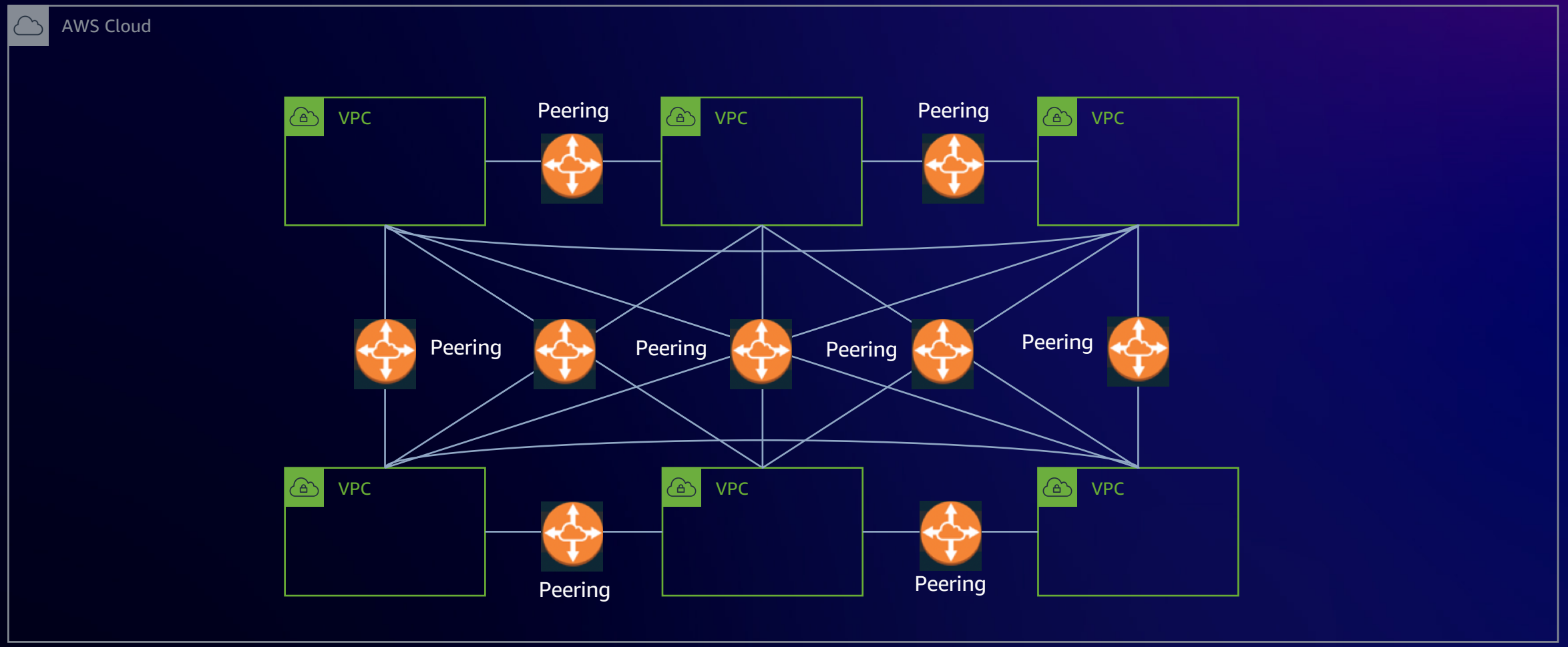
Connect multiple VPCs: VPC Peering

- Scalable and high available
- Supported between AWS accounts
- Supported across AWS Regions
- Bi-directional traffic
- Remote Security groups can be referenced
- Routing policy with Route Tables
  - Not all subnets need to connect to each other
- No overlapping IP addresses
- No transitive routing



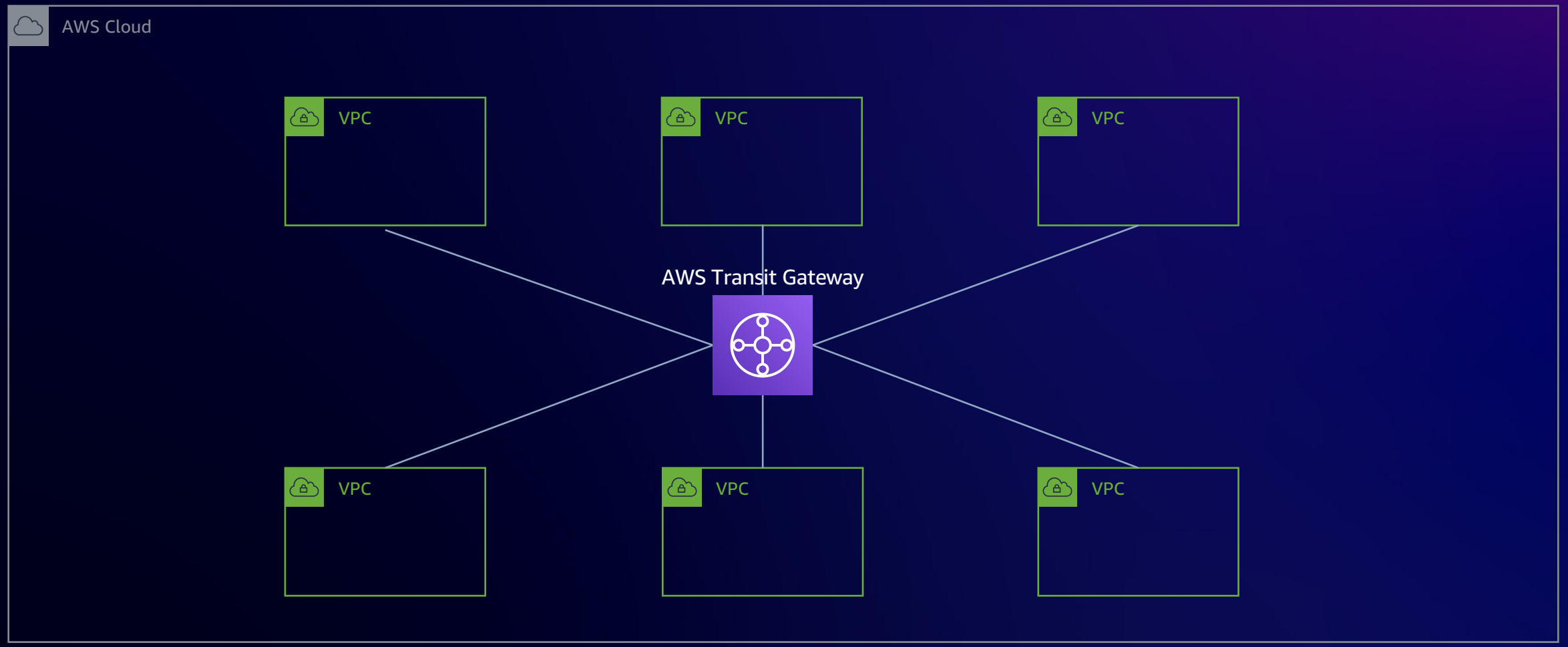
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Connect multiple VPCs: VPC Peering at scale



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

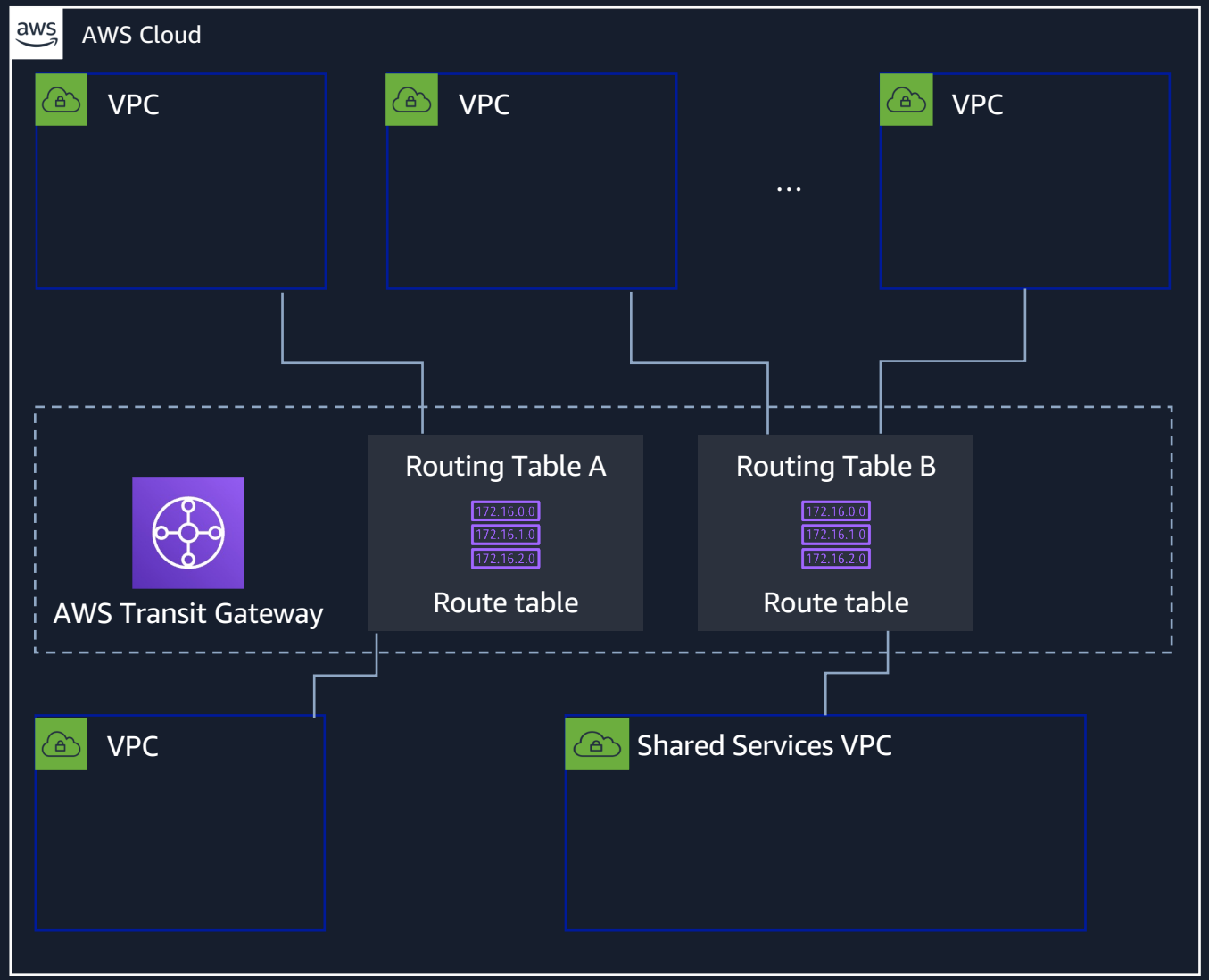
Multiple VPCs access models – AWS Transit Gateway



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Connect multiple VPCs: Transit Gateway

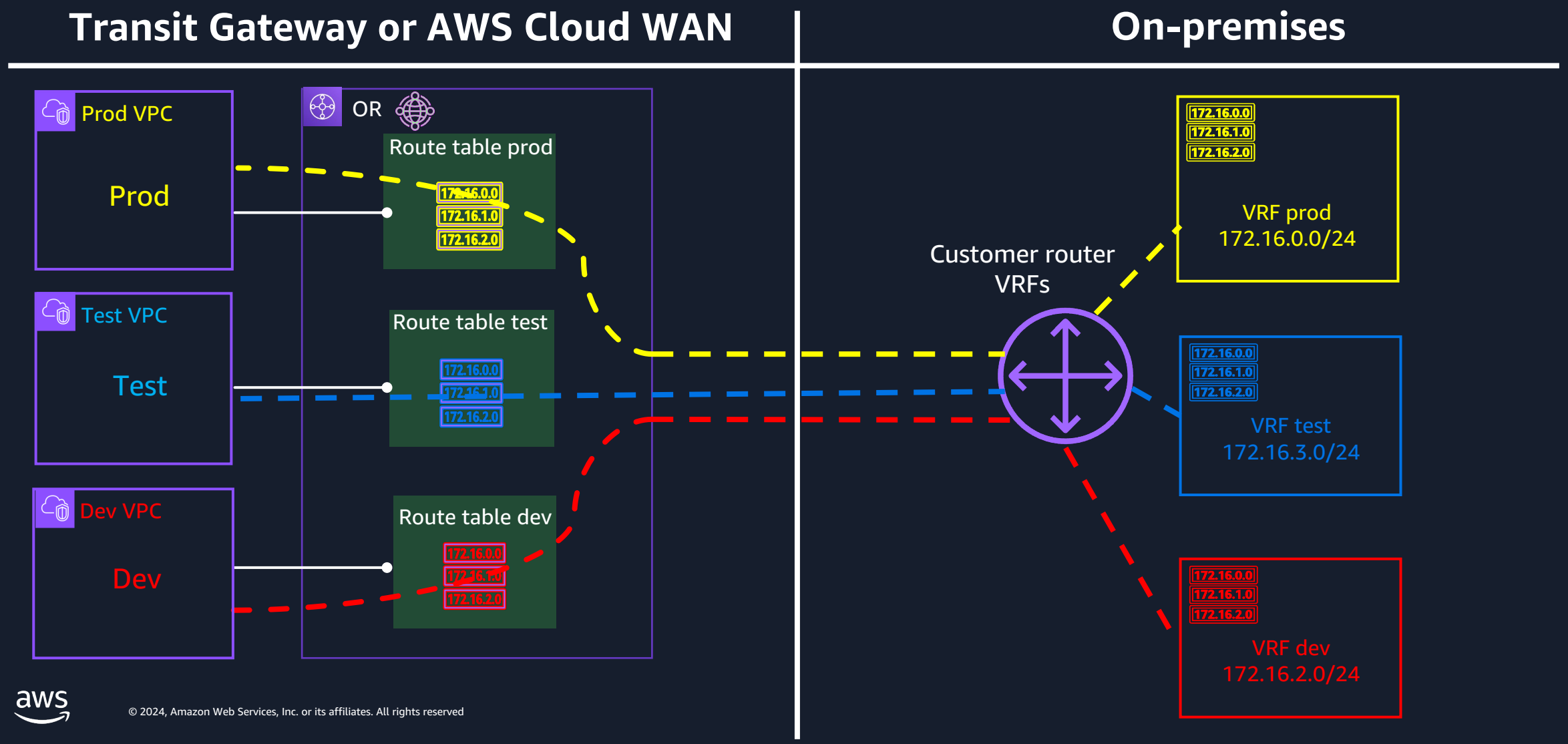
- Connect thousands of VPC across accounts within a region
- Connect your VPCs and on-premises through a single transit gateway
- Centralize VPN and AWS Direct Connect connections
- Control segmentation and data flow with Route Tables
- Hub and Spoke design
- Up to 50 Gbps per attachment (burst)



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Network segmentation

ROUTE SEGMENTATION



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

2. Port security. Security Group and Network ACL

	Security group	Network ACL
Key use case	Access control allow known list of sources	Access control explicit deny specific sources, blacklists
Inspection point	ENI (EC2 instance, RDS database, etc)	VPC subnet
Firewall type	Stateful	Stateless
Evaluation order	Evaluate all rules	Sequential rule evaluation
OSI layer	L3-L4	L3-L4
Rule types	Allow	Allow, Deny
AWS Firewall Manager	Yes	Yes
Pricing	No cost	No cost

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Best Practices for Using Security Groups and NACLs Together

1. **Layered Security**: Use both Security Groups and NACLs for a layered security model. Security Groups can be more granular, while NACLs can apply broader restrictions at the subnet level.

2. **Deny Rules in NACLs**: Leverage NACLs if you need to block specific IPs or ranges that you can't easily handle with Security Groups (since SGs don't support deny rules).

3. **Least Privilege Principle**: Apply the least privilege principle. Only allow traffic that's necessary for your instances and subnets.

4. **Organize Rules**: For NACLs, use a numbering strategy to organize your rules. AWS processes NACL rules in ascending order, so it’s important to order them properly.

5. **Use Separate Security Groups**: For applications with different roles, create separate Security Groups for different instances or tiers (e.g., web, database, application).

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

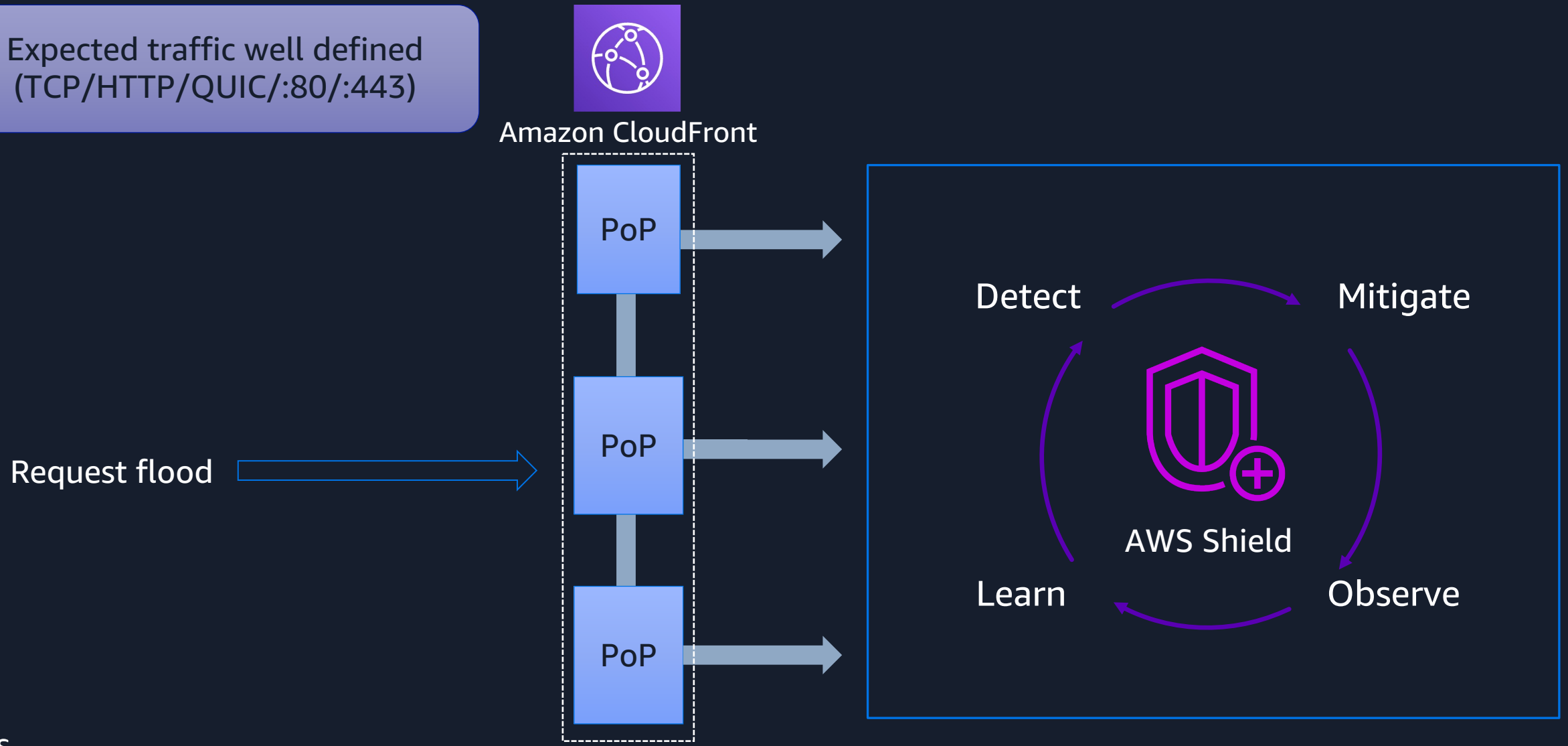
3. Additional Protection: DDoS protection



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

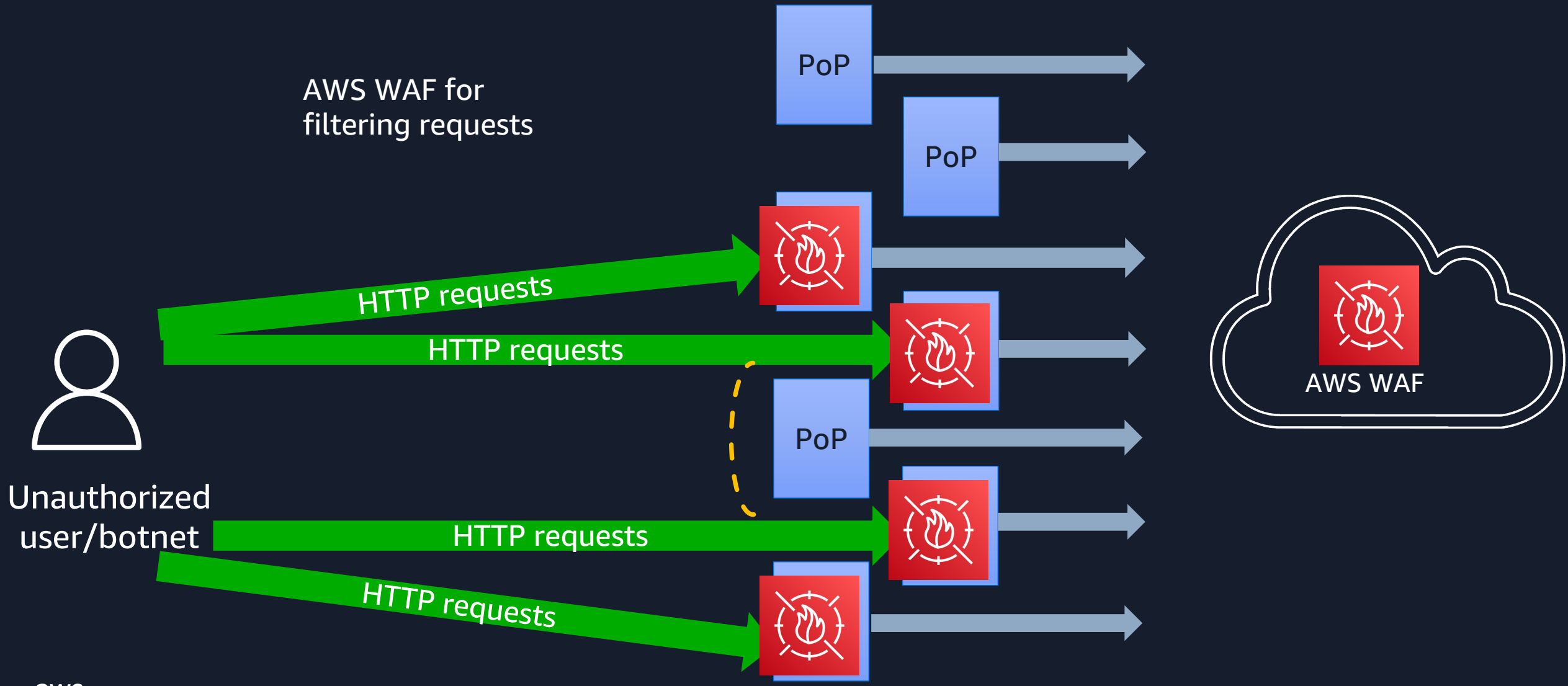
3.1. DDoS protection: Web traffic to CloudFront

Expected traffic well defined
(TCP/HTTP/QUIC/:80/:443)



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

The request flood attack



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

3.2. DDoS protection: DNS traffic to Route 53



Amazon Route 53



AWS Shield

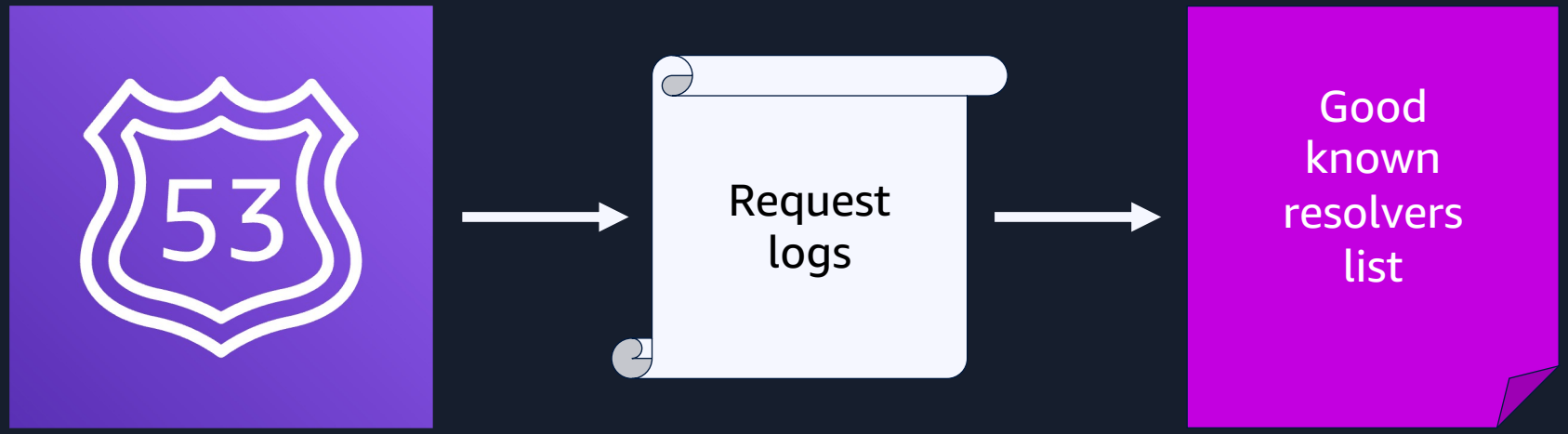
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DDoS protection: DNS traffic to Route 53



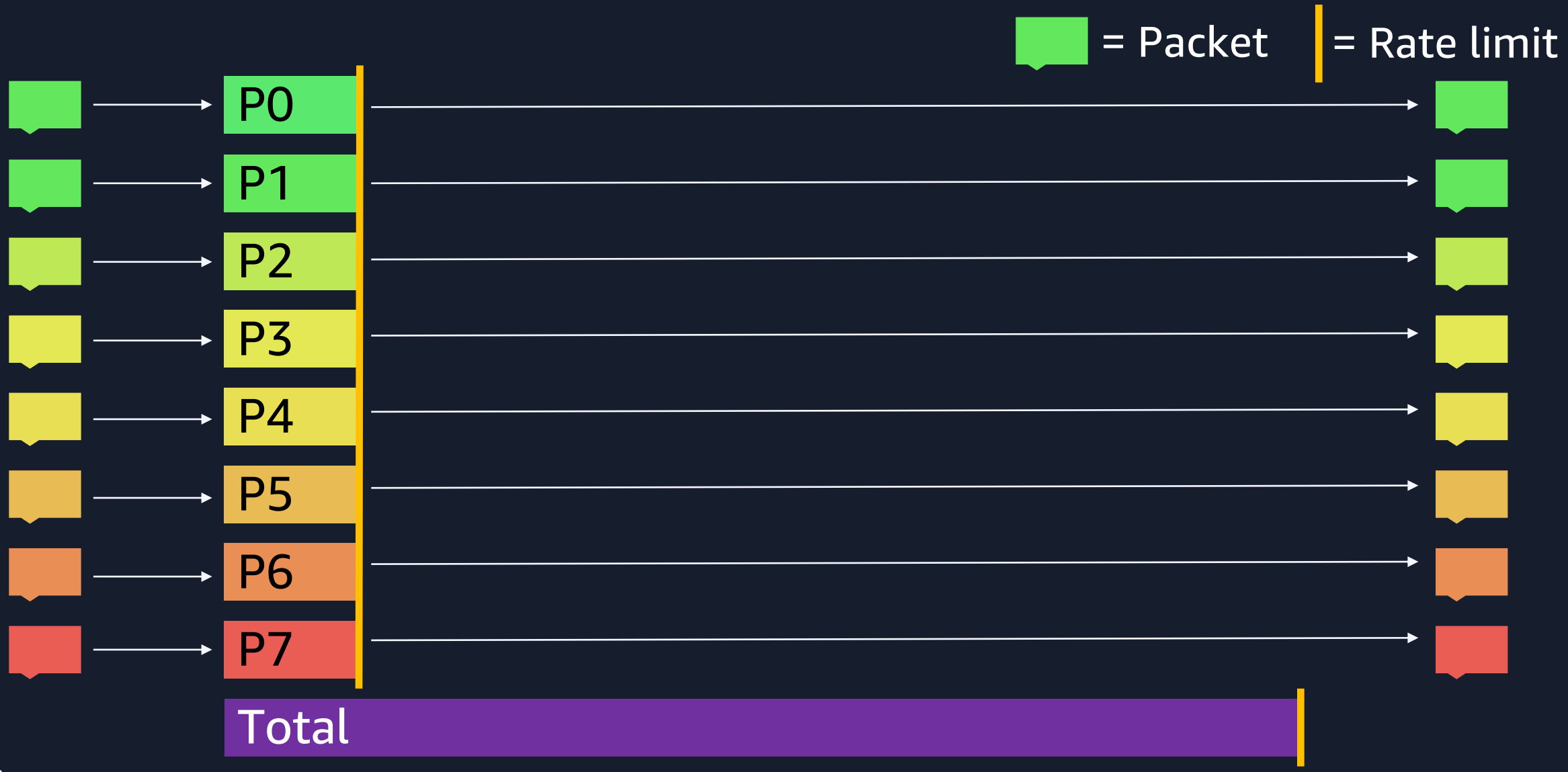
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DNS known good resolvers (DKGR) mitigation



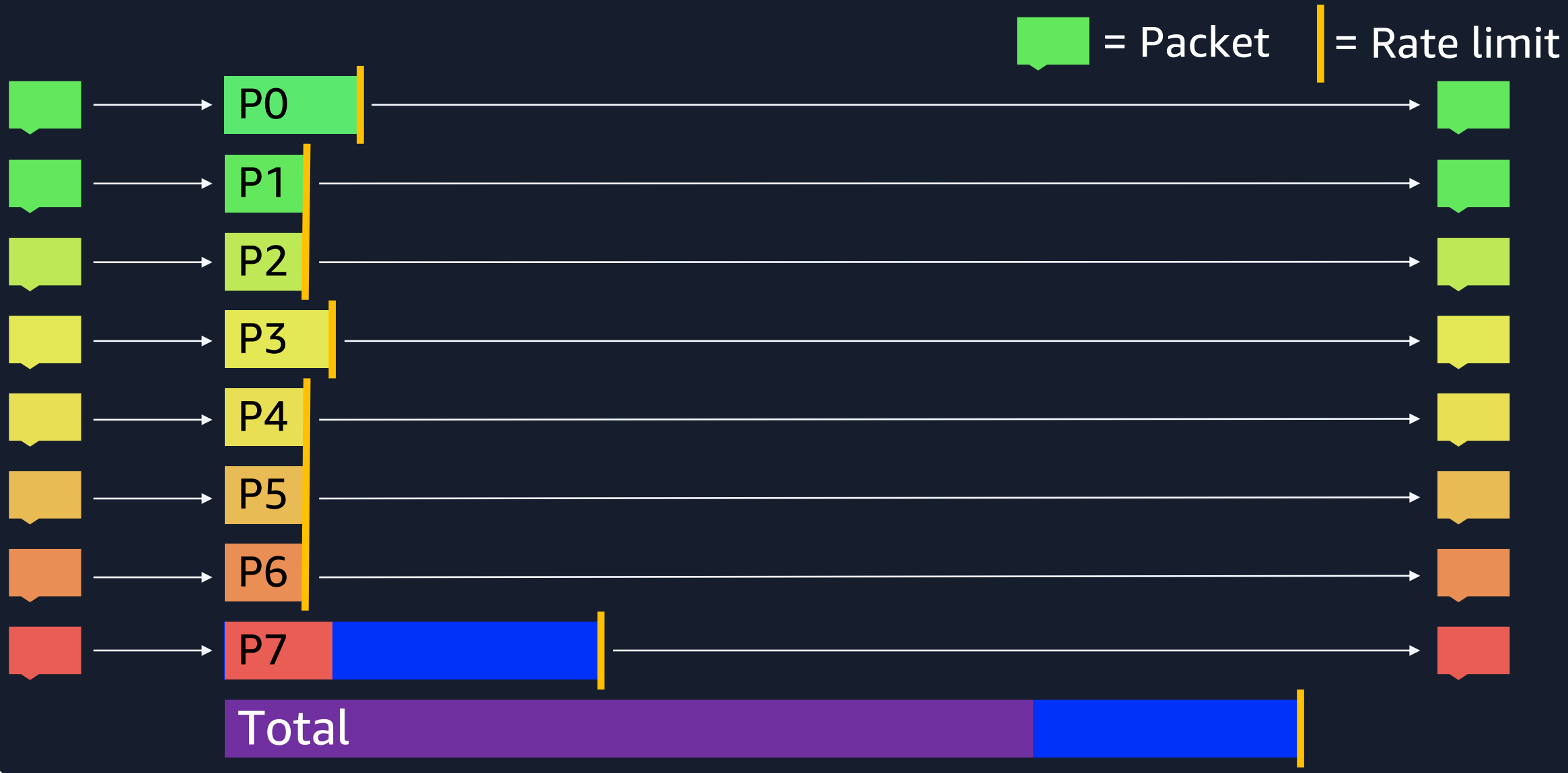
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Traffic shaping mitigation



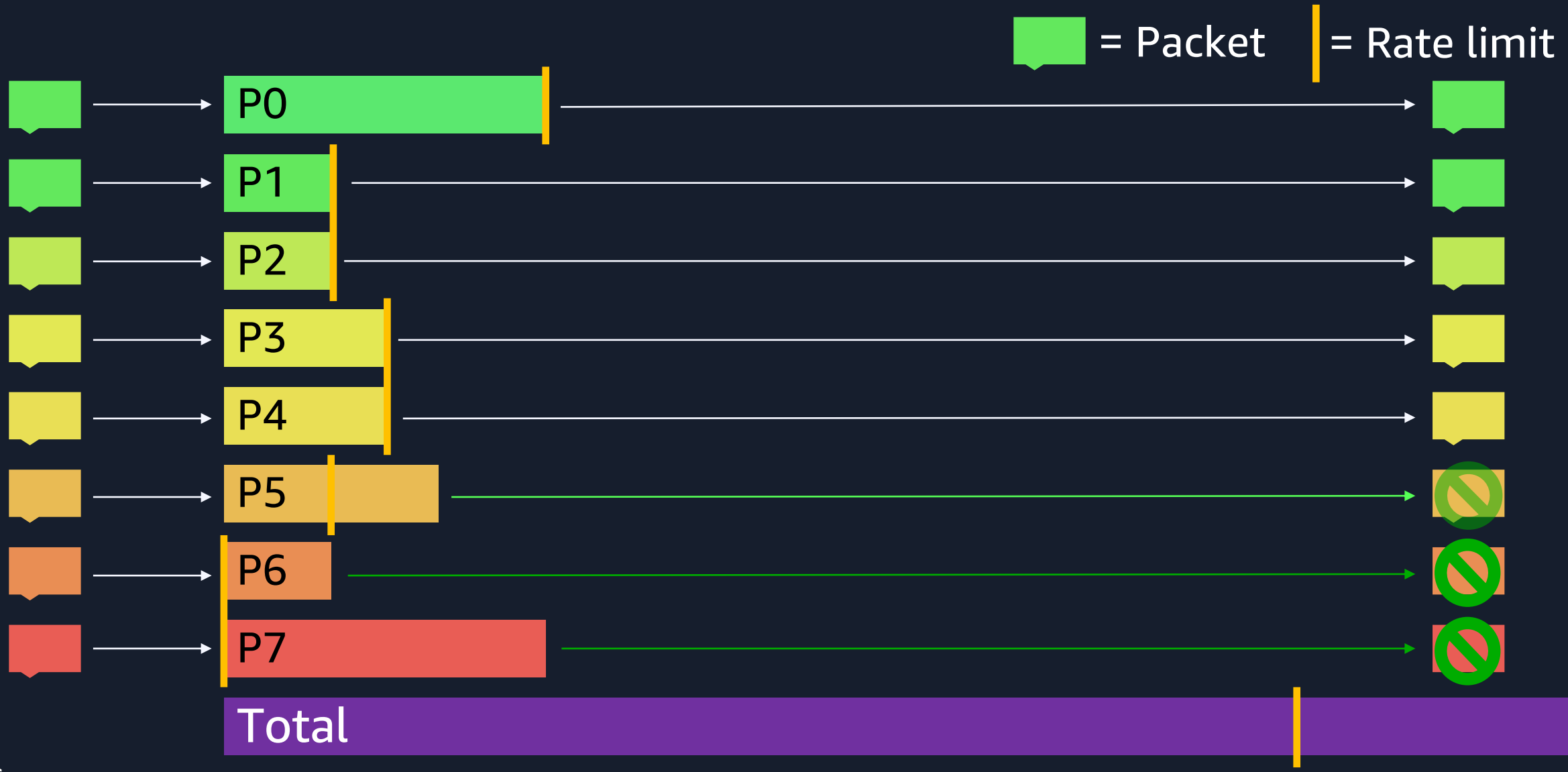
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Traffic shaping: Below rate limit



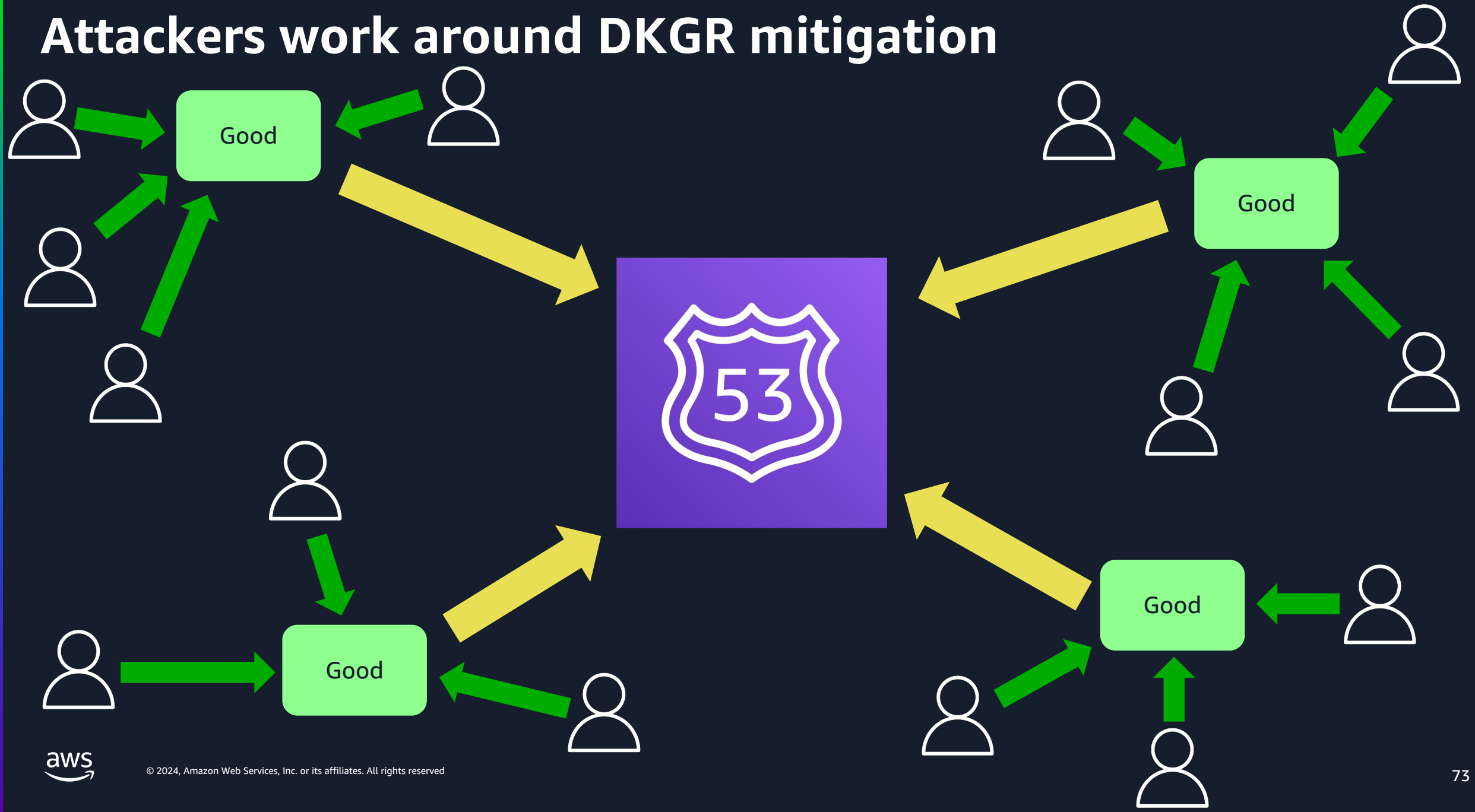
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Traffic shaping: Above rate limit



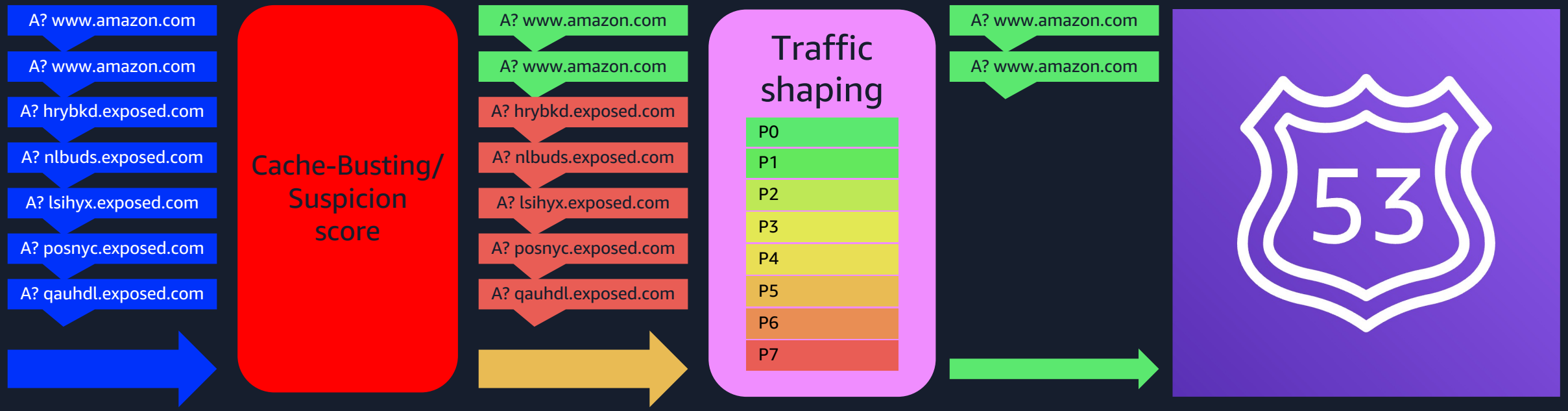
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Attackers work around DKGR mitigation



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Mitigating cache-busting attacks



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

3.2. DDoS protection: DNS traffic to Route 53



Amazon Route 53



AWS WAF

Amazon Route 53 Resolver DNS Firewall policies

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

3.3. DDoS protection: Any traffic to any endpoint

Any Protocol Port





Web applications
VoIP
Non-HTTP apps
Content streaming
DNS
IoT
…

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DDoS protection: Any traffic to any endpoint

"Just monitor endpoint capacity"



Mac instance



M1 Mac instance



T4g instance



T3 instance



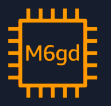
T3a instance



T2 instance



M6g instance



M6gd instance



M6i instance



M6a instance



M5 instance



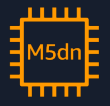
M5a instance



M5d instance



M5n instance



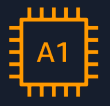
M5dn instance



M5zn instance



M4 instance



A1 instance



C7g instance



C6g instance



C6gd instance



C6gn instance



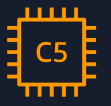
C6i instance



C6a instance



Hpc6a instance



C5 instance



C5d instance



C5a instance



C5ad instance



C5n instance



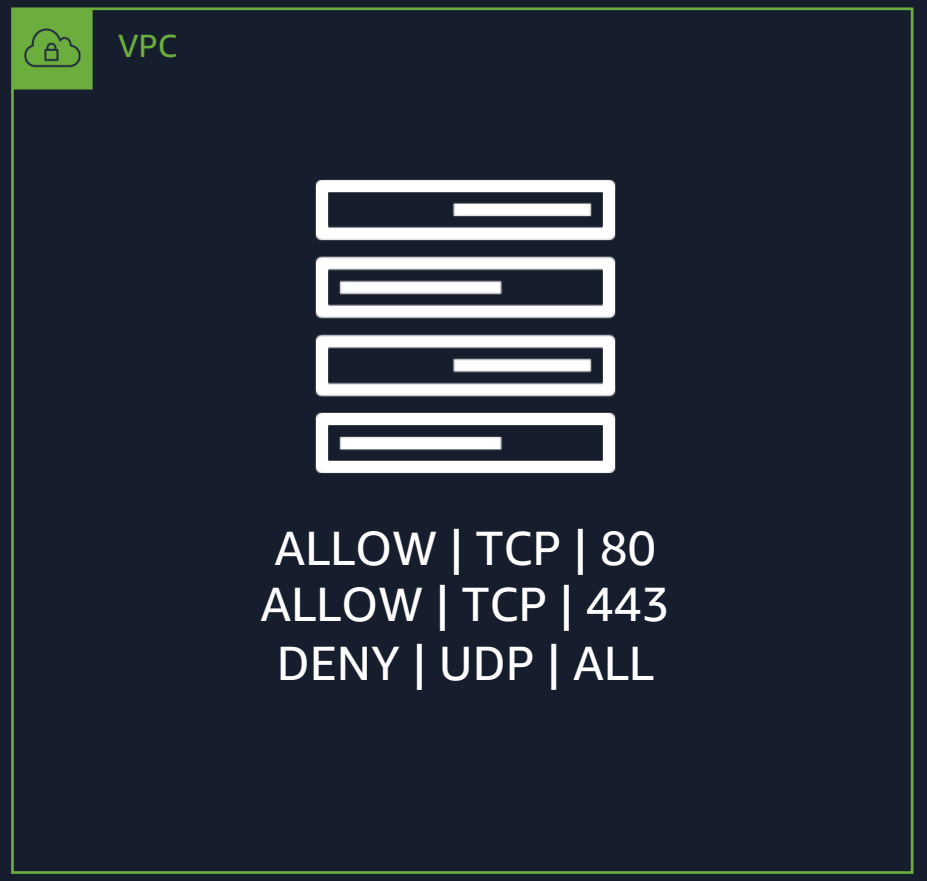
C4 instance

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DDoS protection: NACL



Promote to the border



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DDoS protection: Byte match

```
0000  5d a2 c8 22 02 00 00 00 ad d3 00 00 23 56 73 25   ].."........#Vs%
0010  fa 61 32 4c 00 00 00 00 f0 d9 49 4e 00 00 00 00   .a2L......IN....
0020  79 61 25 0b 03 00 00 00 7b 61 25 0b 9e 27 00 00   ya%.....{a%..'..
0030  a6 02 00 00 fe ff ff ff 6d 6e 00 00 03 00 70 02   ........mn....p.
0040  a5 02 2f 00 ff ff f9 ff ff c1 3f                  ../.......?
```

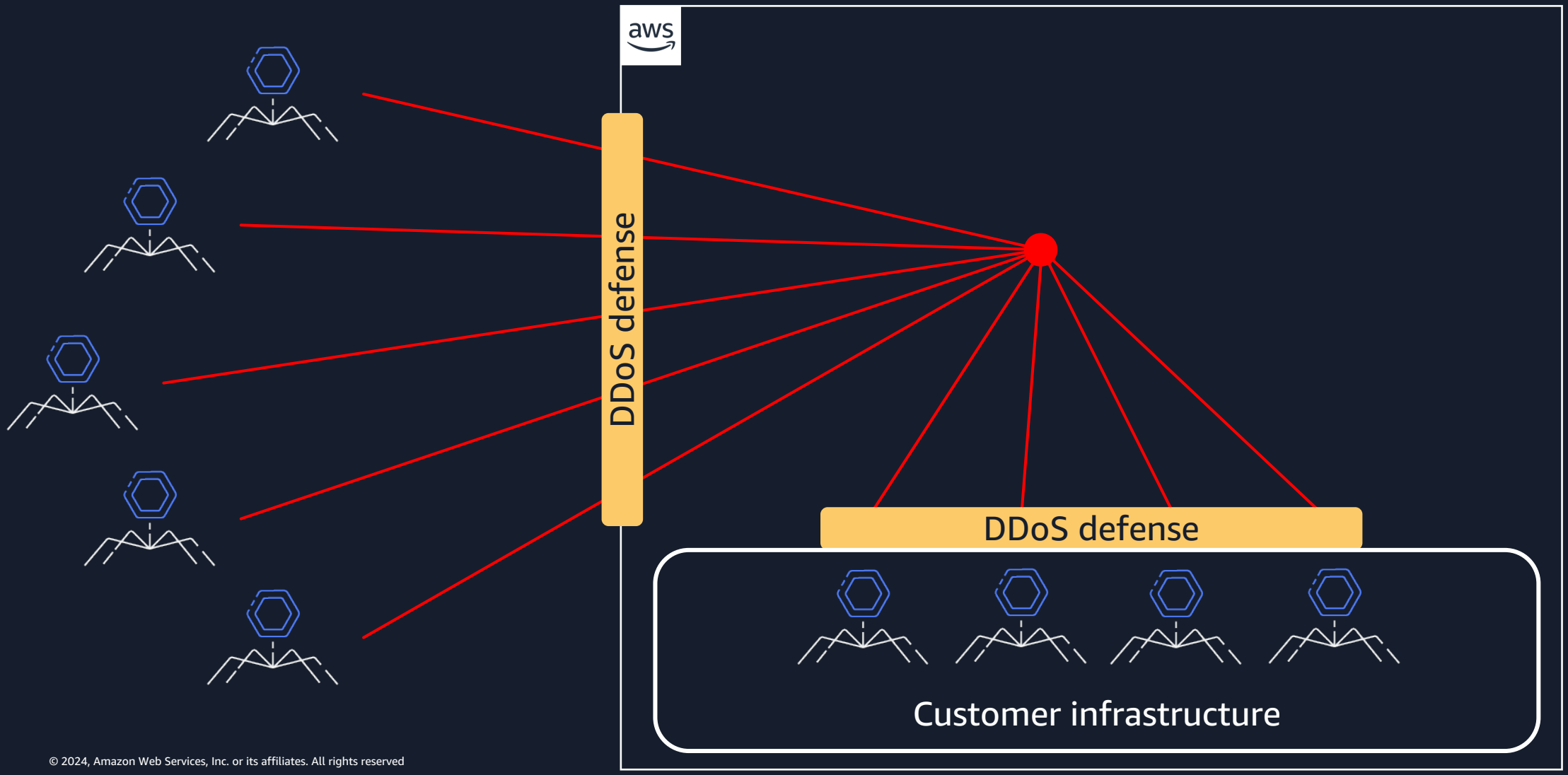




AWS Shield

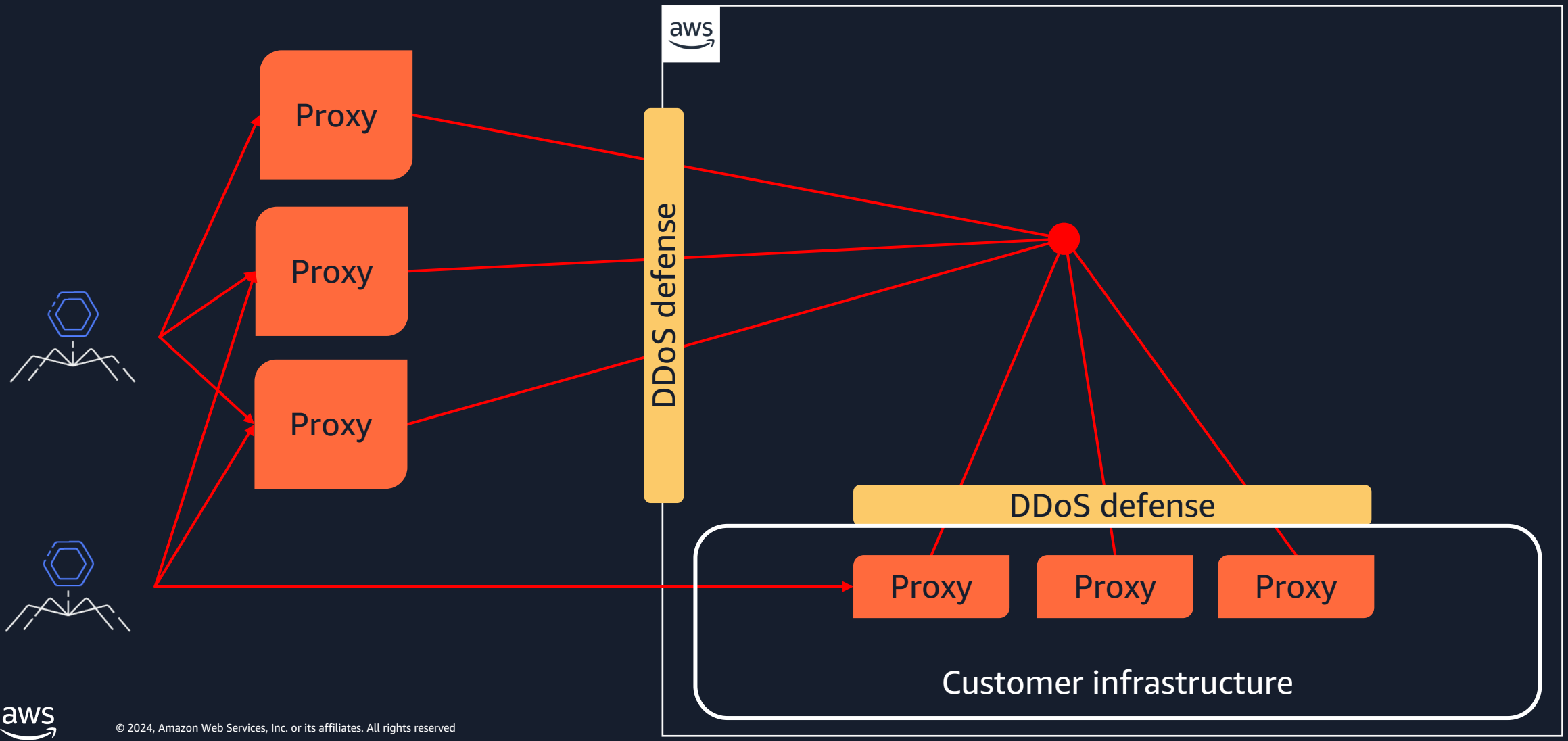
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DDoS protection: When AWS is the source



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

DDoS protection: When AWS is the source



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Framework for thinking about DDoS resilience

Define your security model



Amazon VPC



Network access control list



AWS WAF



Rule



Managed rule



Filtering rule



Labels



Bot control



Bot



Bad bot



AWS Network Firewall



Endpoints



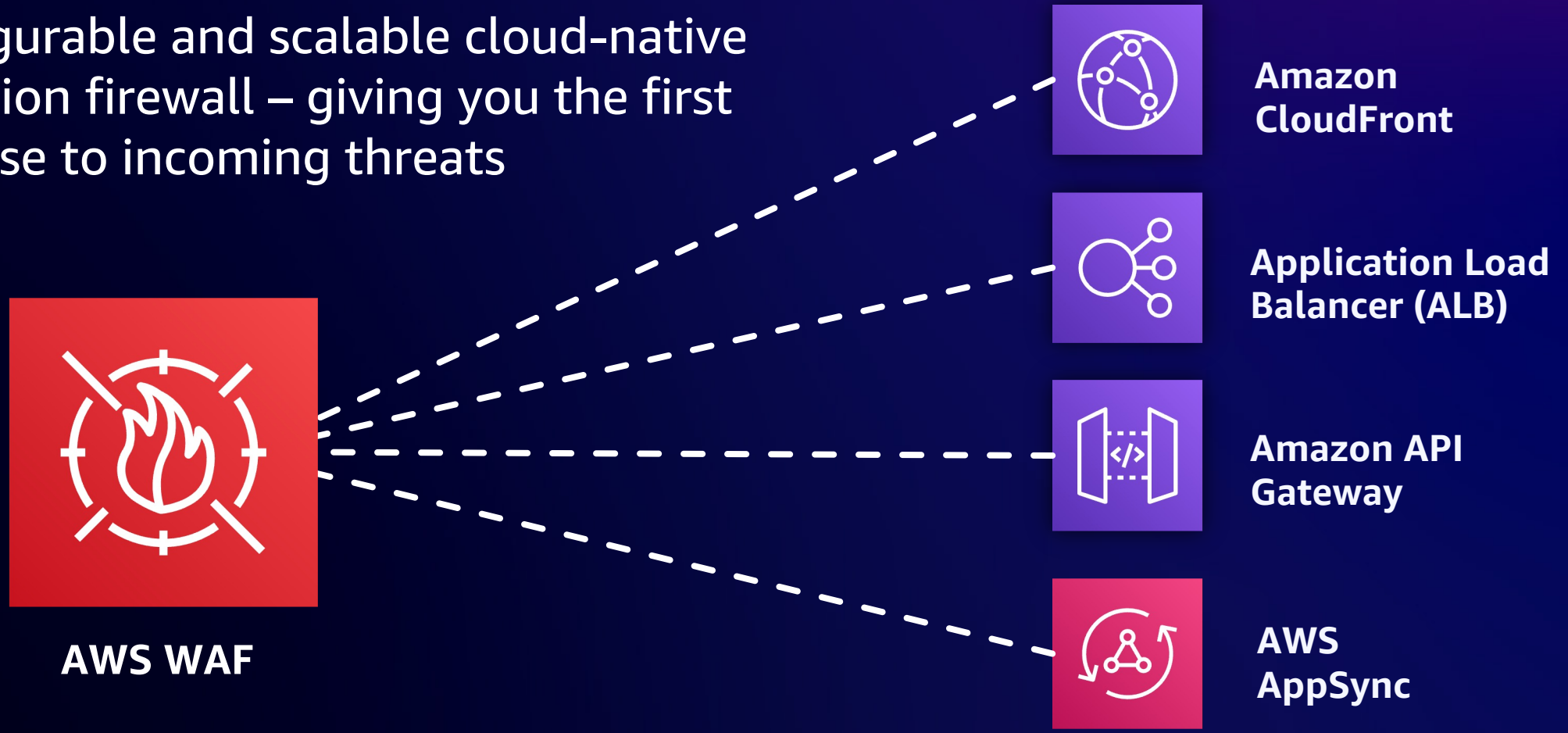
AWS Firewall Manager

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

3. Additional Protection: safeguard web applications

PROTECT APPLICATIONS AGAINST DDOS ATTACKS, WEB ATTACKS AND BOT ATTACKS

Highly configurable and scalable cloud-native web application firewall – giving you the first line of defense to incoming threats



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Takeaway

1. Building a Scalable and Secure Multi-VPC AWS Network Infrastructure https://docs.aws.amazon.com/whitepapers/latest/building-scalable-secure-multi-vpc-network-infrastructure/welcome.html

2. Combine SG and NACL for enhanced security

3. Design multi-layered protection infraftructure to protect your apps.

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Organizational Account Management



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Organizational Account Management

- SCP and API Access
  - Service Control Policies (SCPs): Establishing guardrails for AWS service usage
  - Controlling API access for enhanced security
- SSO vs. STS
  - AWS Single Sign-On (SSO): Centralized identity management and access control
  - AWS Security Token Service (STS): Temporary credentials for fine-grained access
- Control Tower vs. Landing Zone
  - AWS Control Tower: Automated account provisioning and governance at scale
  - Landing Zone concept: Customized framework for multi-account environments

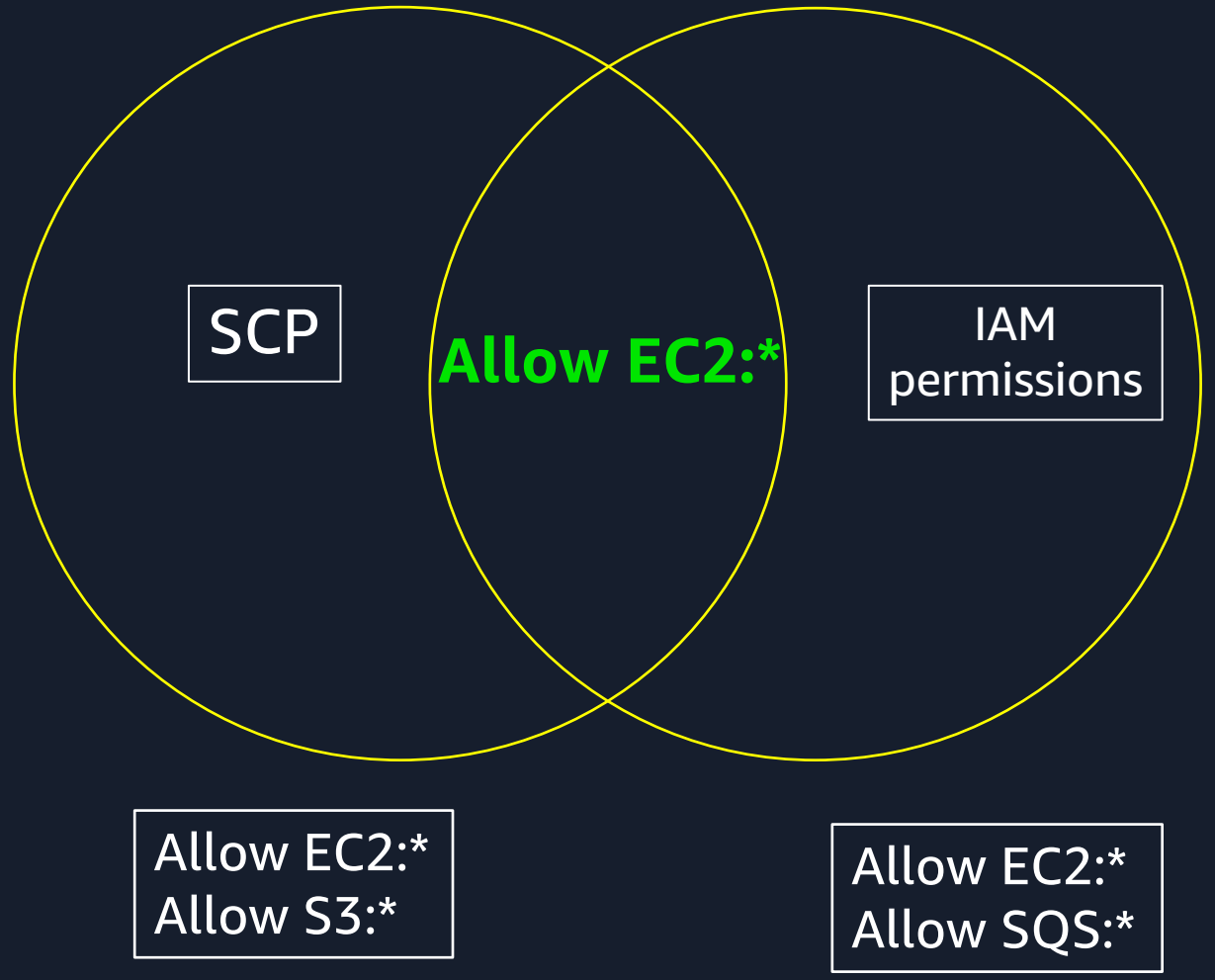
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

1. Service control policies (SCPs)

CENTRALLY CREATE AND APPLY PREVENTATIVE GUARDRAILS FOR YOUR ORGANIZATION

- Define maximum available permissions of the IAM principals for all accounts in your organization
- SCPs do not grant permission
- Can be applied to organization root, OUs, or member accounts

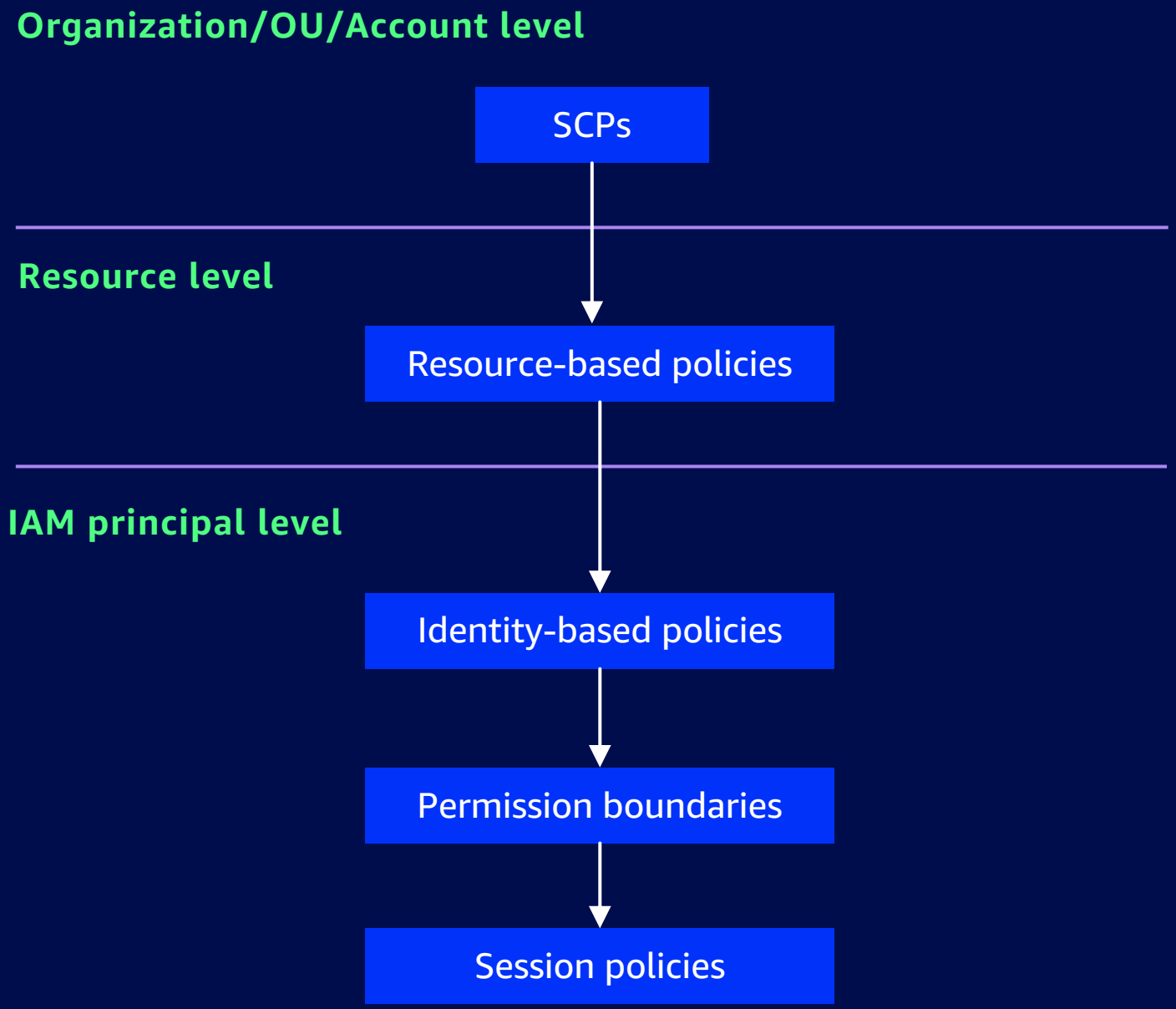
➢ SCPs attached to the root and OUs apply to all OUs and accounts inside of them



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Where do SCPs fit in?

Scope of impact
Intent
Guardrail vs. grant



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved



Governance and security

- Example: Deny changes to security services



Compliance with regulatory standards

- Example: Only allow usage of approved AWS Regions



Privileged access control

- Example: Deny billing modification actions



Implement data perimeters

- Example: Deny IAM principals from accessing public Amazon S3 buckets

When should I use SCPs?

To limit permissions of IAM principals within your organization's member accounts

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

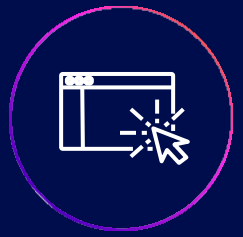
Key considerations

While writing SCPs



Allow vs. deny statements

- Deny actions propagate down the organization
- **FullAWSAccessPolicy**: AWS managed policy attached by default



SCPs do not grant permissions

- Need Identity based and resource based policies to grant access



Quotas

- Policy size: 5,120 bytes
- Maximum SCPs attached per target: 5
- AWS Control Tower preventive guardrails counted

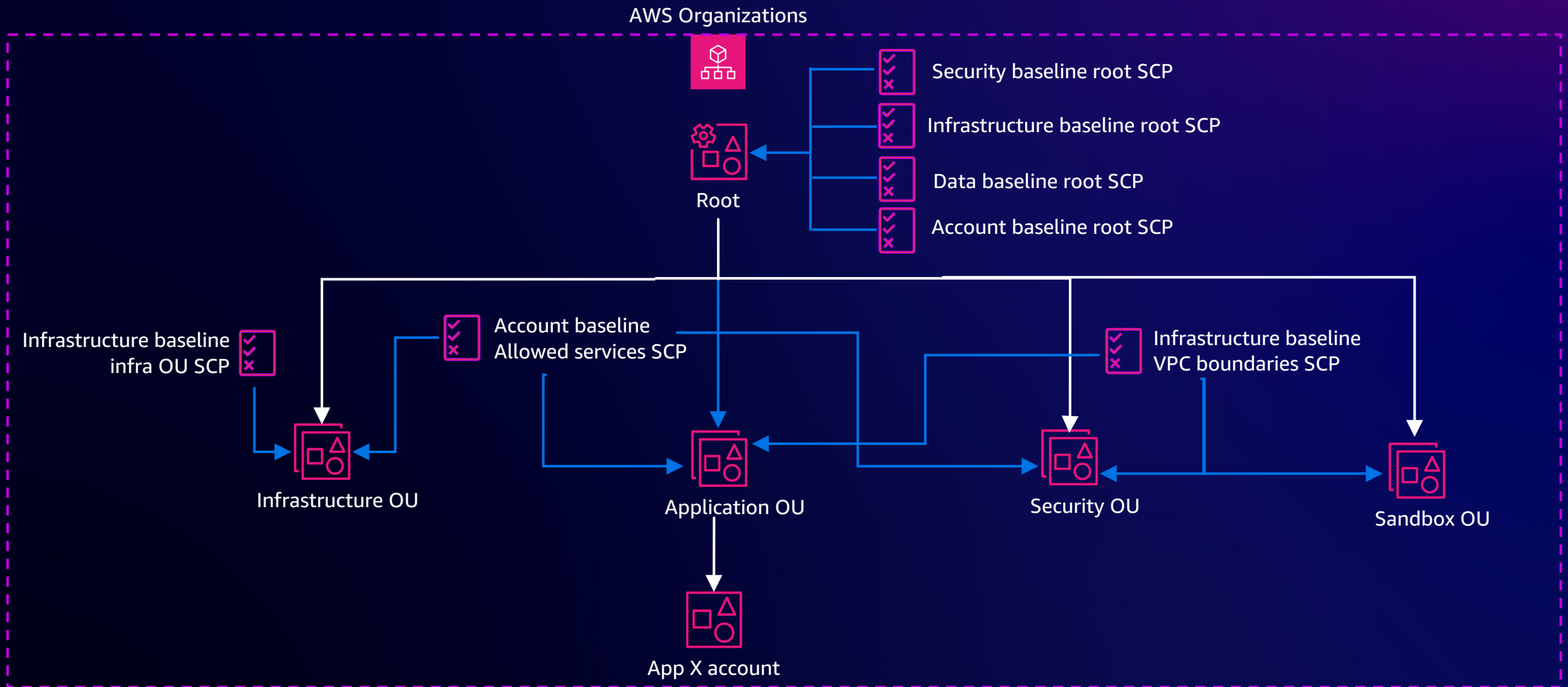


SCPs do not affect

- IAM principals outside of your organization
- IAM principals in management account of your organization

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

SCP attachment strategy



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

AWS establish guardrails for AWS service usage

Deny access to AWS based on the requested region

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAllOutsideEU",
      "Effect": "Deny",
      "NotAction": [
          "iam:*","organizations:*","route53:*",
          ”cloudfront:*”, "support:*"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-central-1","eu-west-1"
          ]
        }
      }
    }
  ]
}
```

Prevent IAM principals from making changes to a common administrative IAM role

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAccessToASpecificRole",
      "Effect": "Deny",
      "Action": [
          "iam:AttachRolePolicy", "iam:DeleteRole",
          "iam:DeleteRolePermissionsBoundary",
          "iam:DeleteRolePolicy", "iam:DetachRolePolicy",
          "iam:PutRolePermissionsBoundary",
          "iam:PutRolePolicy", "iam:UpdateRole",
          "iam:UpdateAssumeRolePolicy",
          "iam:UpdateRoleDescription"
      ],
      "Resource": [
        "arn:aws:iam::*:role/AWS-ADMINISTRATOR-ROLE"
      ]
    }
  ]
}
```

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

AWS establish guardrails for AWS service usage

Stop CloudTrail Being Disabled

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": ”Deny",
      "Action": ”cloudtrail:StopLogging",
      "Resource": "*"
    }
  ]
}
```

No Internet Gateway for Amazon VPC

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": ”Deny",
      "Action": [
            "ec2:AttachInternetGateway”,
        “ec2:CreateInternetGateway”,
        “ec2:AttachEgressOnlyInternetGateway”,
        “ec2:CreateVpcPeeringConnection”,
        “ec2:AcceptVpcPeeringConnection" ],
      "Resource": "*"
    }
  ]
}
```

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

SCP to control API access - key features

- Enables you to control which AWS service APIs are accessible
  - Define the list of APIs that are allowed – *Whitelisting*
  - Define the list of APIs that must be blocked – *Blacklisting*
- Cannot be overridden by local administrator
- Resultant permission on AWS Identity and Access Management (IAM) user/role is the intersection between the SCP and assigned IAM permissions
- Necessary but not sufficient
- Consider using a test OU for testing SCPs

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Whitelisting example

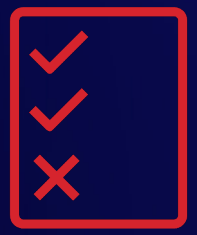
```
{
 "Version":"2012-10-17",
  "Statement":[
   {
    "Effect":"Allow",
    "Action":[
       "EC2:*",
       "S3:*”
        ],
    "Resource":"*"
    }
  ]
}
```



FullAWSAccess

Blacklisting example

```
{
 "Version":"2012-10-17",
  "Statement":[
   {
    "Effect":”Deny",
    "Action":[
         ”SQS:*”
          ],
    "Resource":"*"
    }
  ]
}
```



FullAWSAccess

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Considerations

Whitelisting

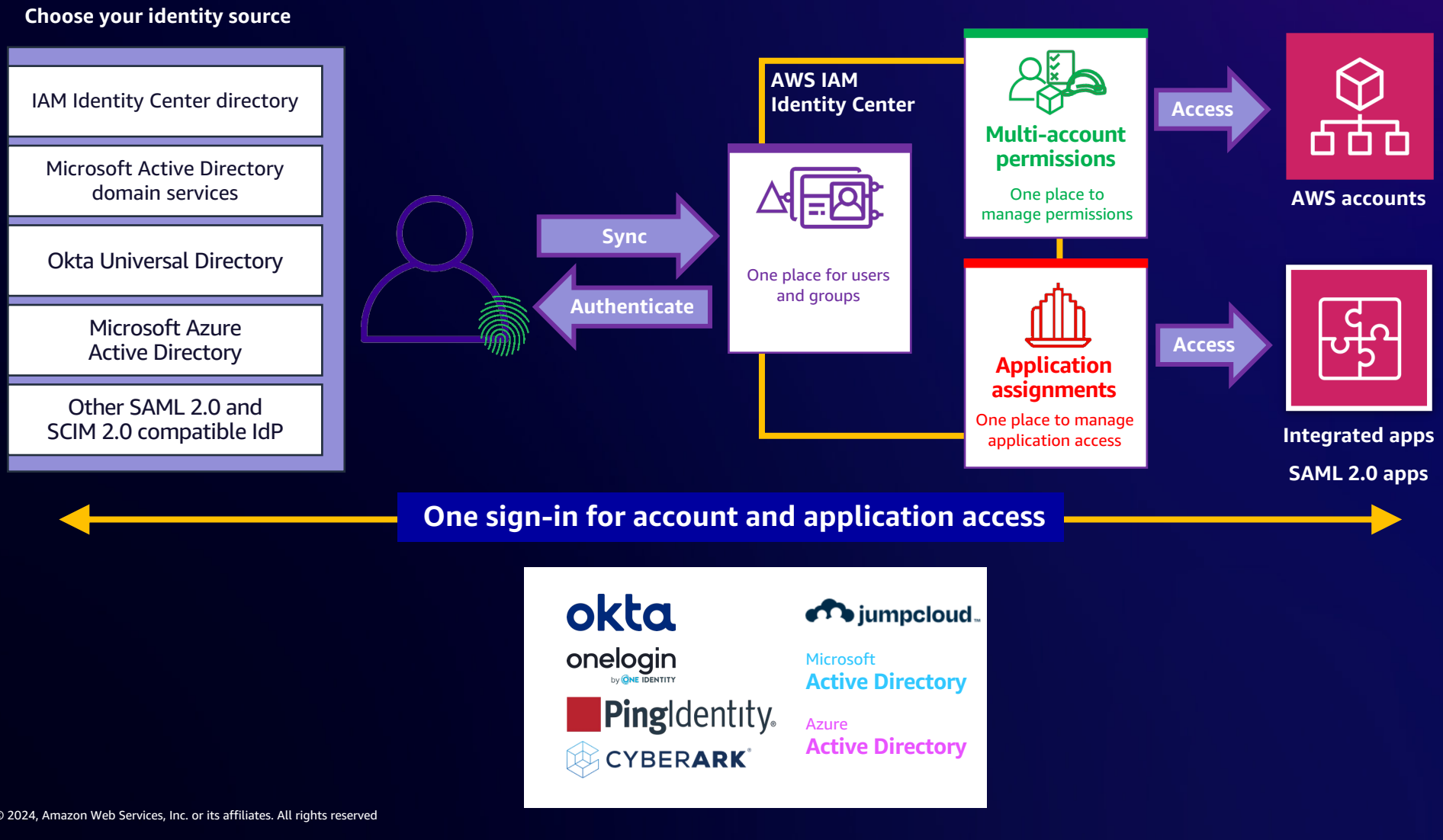
- Tends to be less permissive
- Use wildcards to compress specific action types (i.e., list*, get*, etc.) to stay within policy size limits
- Updates are required to allow access to new AWS services

Blacklisting

- Tends to be more permissive
- Less maintenance
- Easier to stay within the size limits
- Specify conditions, resources, and NotAction to deny access across accounts in your organization or OU
- Testing of new policies can be easier

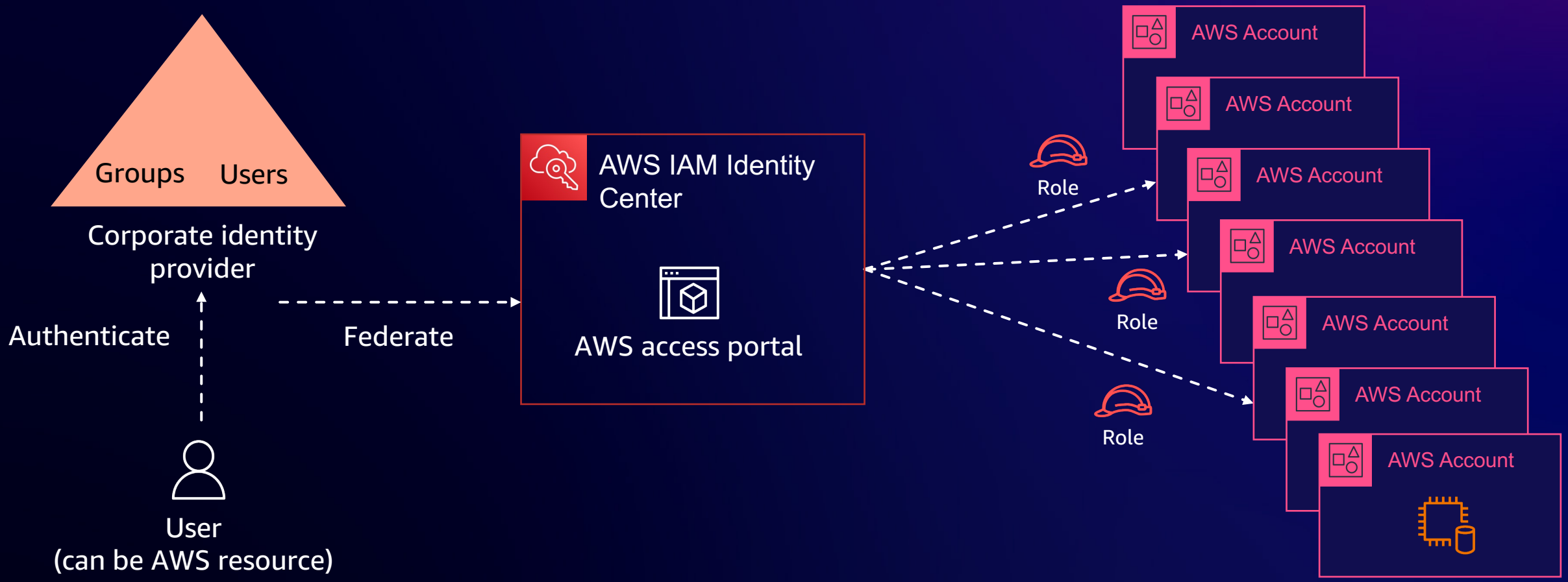
© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

2. SSO vs. STS. What AWS IAM Identity Center is?



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

2. SSO vs. STS. Temporary access pattern (STS)



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

2. SSO vs. STS

Feature	*AWS SSO (Single Sign-On)*	*AWS STS (Security Token Service)*
Purpose	Centralized identity and access management for multiple accounts	Temporary, limited-privilege credentials for AWS resources access
Authentication Method	Uses internal IAM or External Identity Provider (IdP) such as Microsoft AD or Okta	Provides temporary credentials (Access Key, Secret Key, Session Token)
Credential Lifetime	Based on session settings (e.g., 1 hour, 12 hours, etc.)	Temporary credentials with customizable duration (from a few minutes to a maximum of 12 hours)
Session Management	Centralized, with access to multiple accounts and apps in a single user session	Each session is scoped by the temporary credentials and specific policies
User Type	Primarily human users (employees, contractors)	Both human users and programmatic access for applications or services
Primary Service	Identity and Access Management across AWS accounts and apps	Short-term credential generation for AWS resources
User Interface	Web-based console for managing users, roles, and permissions	No specific UI; credentials managed programmatically or through AWS Console

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

3. Control Tower vs Landing Zone.

What do you want to do on AWS?

Secure & compliant

Meets the organization's security and auditing requirements

Scalable & resilient

Ready to support highly available and scalable workloads

Adaptable & flexible

Configurable to support evolving business requirements

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

You need “a” landing zone

- A configured, secure, scalable, multi-account AWS environment based on AWS best practices
- A starting point for net new development and experimentation
- A starting point for migrating applications
- An environment that allows for iteration and extension over time



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

The Landing Zone solution – nice to have

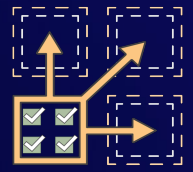
An easy-to-deploy solution that automates the setup of **new AWS multi-account environments**



Based on AWS best practices and recommendations



Initial security and governance controls



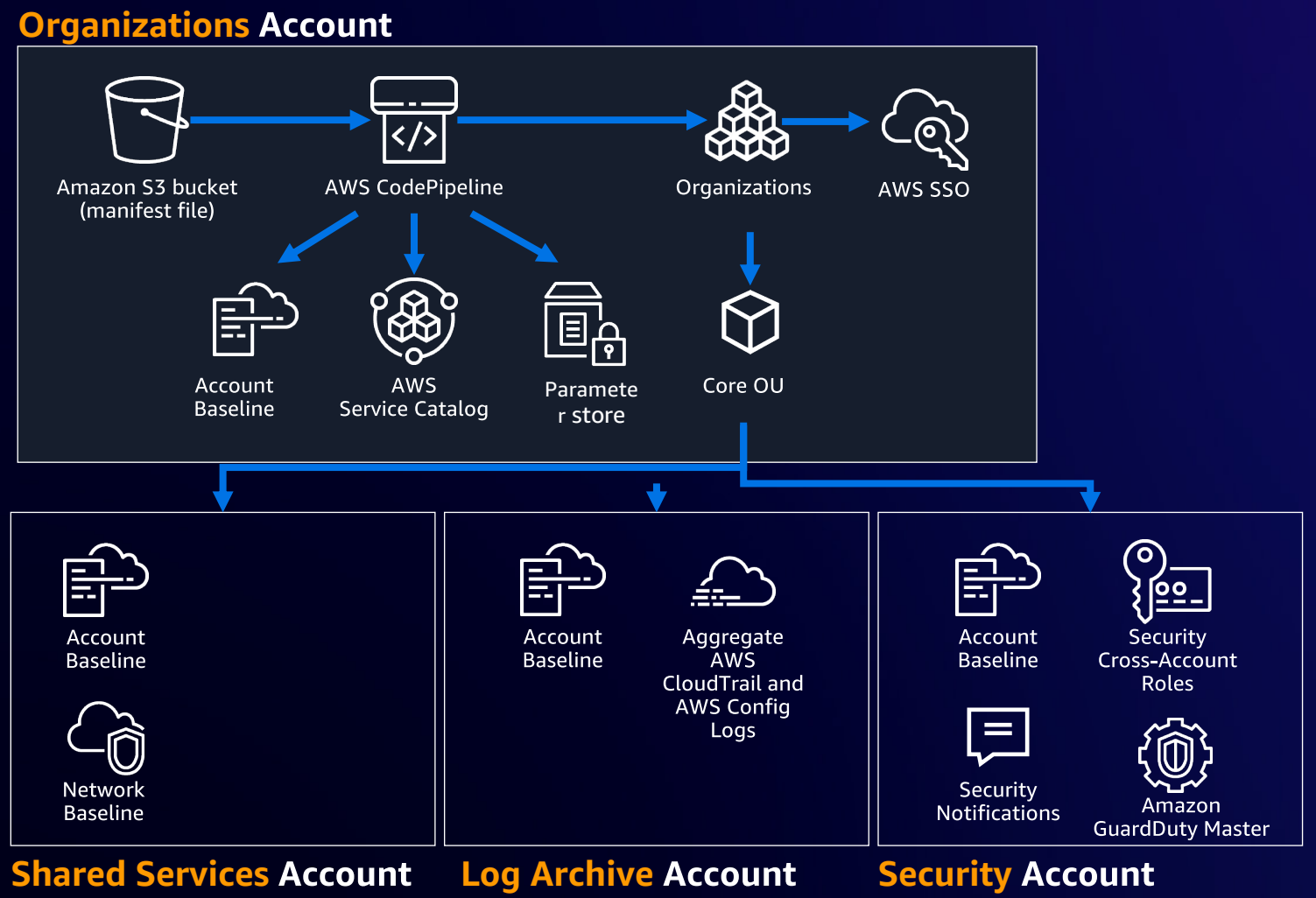
Baseline accounts and account vending machine



Automated deployment

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Landing Zone structure—Basic



Organizations Account

- Account Provisioning
- Account Access (SSO)

Shared Services Account

- Active Directory
- Log Analytics

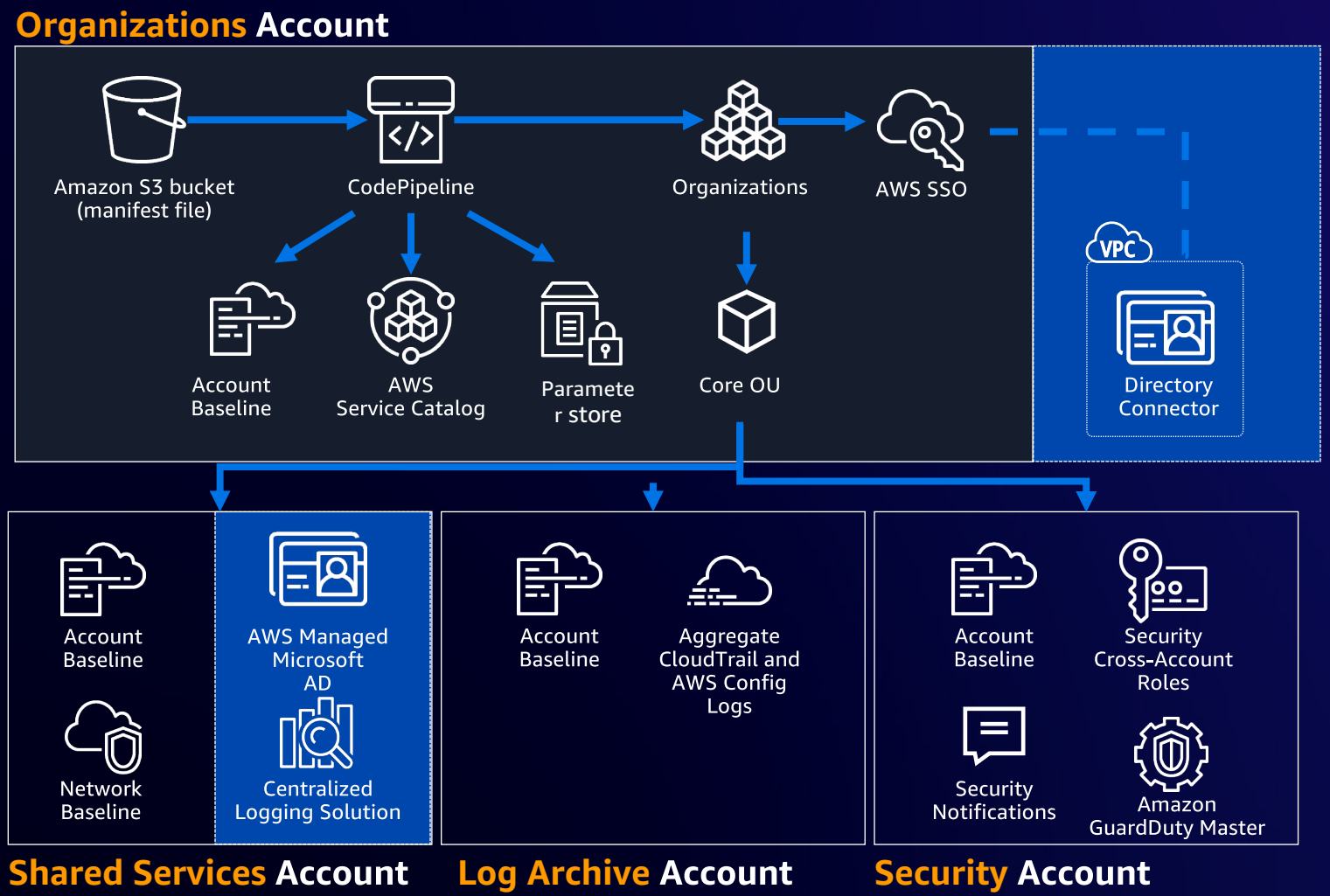
Log Archive

- Security Logs

Security Account

- Audit/Break-glass

Landing Zone structure—With optional add-ons



Organizations Account

- Account Provisioning
- Account Access (SSO)

Shared Services Account

- Active Directory
- Log Analytics

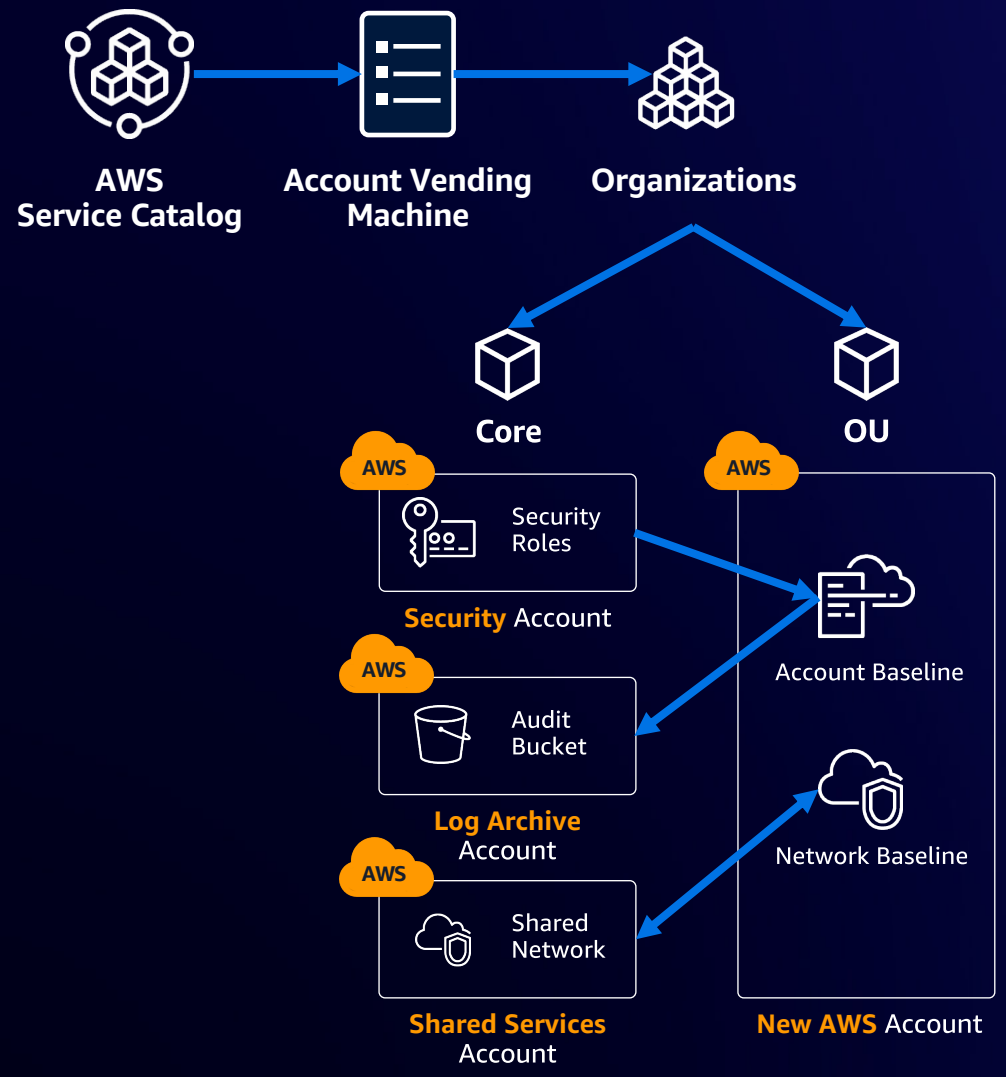
Log Archive

- Security Logs

Security Account

- Audit/Break-glass

Account Vending Machine



Account Vending Machine (AWS Service Catalog)

- Account creation UI
- Account baseline versioning
- Launch constraints

Creates/updates AWS account

Apply account baseline stack sets

Create network baseline

Apply account security control policy

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

What you get at the end

Account management

- Framework for creating and baselining a multi-account environment
- Initial multi-account structure including security, audit, & shared service requirements
- An Account Vending Machine that enables automated deployment of additional accounts with a set of security baselines

---

Identity & access management

- User account access managed through AWS Single Sign-On federation
- Cross-account roles enable centralized management

Security & governance

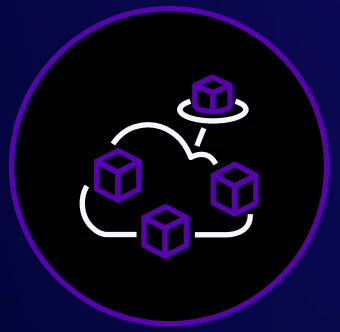
- Multiple accounts enable separation of duties
- Initial account security and AWS Config rules baseline
- Network baseline

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

AWS Control Tower: Easiest way to set up and govern AWS at scale



Enable



Provision



Operate

Business agility + governance control

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Enable governance



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Takeaway

1. Best Practices for AWS Organizations Service Control Policies https://aws.amazon.com/blogs/industries/best-practices-for-aws-organizations-service-control-policies-in-a-multi-account-environment/

2. AWS IAM IC utilise STS under the hood)))

3. Don’t reinvent the wheel (and use AWS Control Tower).

© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved

Thank you.



© 2024, Amazon Web Services, Inc. or its affiliates. All rights reserved